

BUSINESS CONTINUITY MITO O REALTÀ?

LA CONTINUITÀ NELLA DISCONTINUITÀ

GUIDA TEORICA E PRATICA

A cura di:

**FEDERICA MARIA RITA LIVELLI
CHIARA CAVICCHIOLI**

WWW.ICTSECURITYMAGAZINE.COM

Indice

About The Author

PARTE I

1.	Perché abbiamo predisposto questo white paper	Pag. 7
2.	Business Continuity – Le Origini	Pag. 7
3.	Definizione della Business Continuity	Pag. 8
4.	ISO 22301 – Business Continuity Management System (BCMS)	Pag. 9
4.1.	Business Continuity Plan (BCP) resilienti: come progettarli?	Pag. 9
4.2.	La ISO 22301	Pag. 10
4.3.	Punti da “0” a “3”	Pag. 11
4.4.	Punti da “4” a “10”	Pag. 11
4.5.	Punto 3.0 - Termini & Definizioni	Pag. 12
4.6.	Perché è importante implementare un BCMS?	Pag. 14
5.	Le fasi della Business Continuity	Pag. 15
5.1.	Punto 4 – Conoscere il contesto	Pag. 18
5.2.	Punto 5.0 – Leadership	Pag. 19
5.3.	Punto 6.0 – Pianificazione	Pag. 22
5.4.	Punto 7.0 – Supporto	Pag. 23
5.5.	Punto 8.0 – Attività Operative (Operation)	Pag. 25
6.	La BIA	Pag. 25
6.1.	Da dove iniziamo ad eseguire una BIA?	Pag. 27
6.2.	Una domanda lecita: viene prima la Business Impact Analysis (BIA) o il Risk Assessment (RA)?	Pag. 30
6.3.	Strategie & soluzioni di BC	Pag. 32
6.4.	I BCP e Procedure di BC	Pag. 34
6.5.	Esercizi & Test	Pag. 36

6.6.	Valutazione della documentazione e funzionalità della Business Continuity	Pag. 38
7.	Punto 9 – Valutazione delle Prestazioni	Pag. 38
8.	Punto 10 – Miglioramento	Pag. 39
9.	Come progettare un Business Continuity Plan (BCP) – Esempio di struttura	Pag. 39
10.	Disaster Recovery	Pag. 41

PARTE II

11.	Introduzione alla Parte II	Pag. 45
12.	Contesto dell'organizzazione	Pag. 45
13.	Leadership	Pag. 46
14.	Pianificazione, Supporto e Attività Operative	Pag. 48
14.1.	Template analisi di impatto BIA	Pag. 48
14.2.	Informazioni aggiuntive BIA	Pag. 53
14.3.	Calcolo RTO	Pag. 58
14.4.	Calcolo dell'RPO	Pag. 61
14.5.	Probabilità di accadimento	Pag. 61
14.6.	Perimetro dei processi oggetto di analisi	Pag. 63
14.7.	Soluzioni di Continuità Operativa	Pag. 65
15.	Valutazione delle prestazioni	Pag. 66
15.1.	Test	Pag. 66
15.2.	Fornitori e interdipendenze	Pag. 71
16.	Piano di continuità operativa (BCP – Business Continuity Plan)	Pag. 77
17.	Miglioramento continuo	Pag. 82

About The Author



Federica Maria Rita Livelli

BUSINESS CONTINUITY, RISK MANAGEMENT AND CYBER RESILIENCE EXPERT

Consulente in Risk Management & Business Continuity, svolge un'attività di diffusione e sviluppo della cultura della resilienza presso varie istituzioni e università italiane e straniere.

Membro de: BCI Cyber Resilience Committee, ANRA - Direttivo & Comitato Scientifico, CLUSIT -Comitato Scientifico & Comitato Artificial Intelligence/AIXA, ENIA - Comitato Scientifico, FERMA – Digital Committe, UNI - Comitato Tecnico UNI/CT 016/GL 89 “Gestione dell’innovazione” (ISO/TC 279). Relatrice e moderatrice in diversi seminari, conferenze nazionali ed internazionali, è anche autrice di numerosi articoli su diverse riviste online italiane e straniere.

Ha partecipato, in qualità di co-autrice, a: Edizioni 2020, 2021, 2022 ,2023 e 2024 del Rapporto Clusit - Cyber Security; Libri tematici CLUSIT rif. Intelligenza Artificiale (2020) e Rischio Cyber (2021), Supply Chain Risk (2023); Libro “Lo Stato in Crisi” ed. Angeli (2022).

About The Author



Chiara Cavicchioli

DIGITAL AND OPERATIONAL RESILIENCE AND CRISIS MANAGEMENT SPECIALIST. CERTIFICATA FERMA RIMAP & AMBCI

Ha maturato esperienza nell'ambito della Continuità Operativa, Crisis Management e Resilienza Digitale in ambito finanziario, anche grazie alle esperienze lavorative svolte presso primari istituti bancari.

Autrice di alcuni articoli pubblicati dal Business Continuity Institute (BCI).

PARTE I

**FOCUS SULLA ISO 22301 E SULLE
VARIE FASI DI IMPLEMENTAZIONE**

A cura di:

FEDERICA MARIA RITA LIVELLI

1. Perché abbiamo predisposto questo white paper

Lo scopo di questo White Paper è fornire degli spunti pratici su come iniziare a incorporare i principi della *Business Continuity*, oltre a fornire un ordine progressivo dei vari step di implementazione, seguendo quanto indicato dalla ISO 22301.

È doveroso ricordare che non esiste un unico modo per implementare la *Business Continuity*, soprattutto considerando il contingente scenario caratterizzato da policrisi e permacrisi, oltre che da un processo accelerato di digitalizzazione e innovazione che implica organizzazioni particolarmente resilienti, agili e flessibili.

Il White Paper consta di due parti, precisamente:

- **PARTE I** - Focus sulla ISO 22301 e sulle varie fasi di implementazione;
- **PARTE II** - Guida teorica e pratica di un Sistema di Gestione di *Business Continuity* in ambito finanziario.

2. Business Continuity – Le Origini

Si iniziò a parlare di *Business Continuity* negli USA, a partire dalla seconda metà degli anni '70 del secolo scorso, a fronte del diffondersi dell'*Information Technology* nelle varie organizzazioni, quando apparve evidente come, dinnanzi al malfunzionamento di un sistema IT, fosse impossibile tornare a processi manuali. Si cominciò, quindi, a riflettere su come fosse necessario garantire la continuità dei processi IT: furono allora concepite le prime soluzioni di *Disaster Recovery*, per preparare le organizzazioni a reagire prontamente agli eventi distruttivi.

In particolare, la metodologia dell'Analisi d'Impatto Operativo (*Business Impact Analysis*) si sviluppò nei primi anni '80 per il settore IT. La disciplina della *Business Continuity* si è poi evoluta nei Paesi anglosassoni – come UK e Australia – e dagli anni '90 è stata applicata anche ad altri ambiti, come risorse umane, asset strategici e processi aziendali. In questo

periodo il British Standards Institution (BSI) pubblicò il primo standard per la Sicurezza Informatica, che si è evoluto nell'attuale norma ISO/IEC 27001, sottolineando la necessità di garantire la continuità in termini di disponibilità dei dati. Diverse associazioni professionali emersero, promuovendo un approccio olistico, teso cioè alla protezione di tutte le attività di un'organizzazione, non solo quelle IT.

Dopo gli eventi dell'11 settembre 2001, l'attenzione si è estesa anche alla Gestione della Crisi (*Crisis Management*), portando la *Business Continuity* a diventare parte della famiglia degli standard dei sistemi di gestione, culminando nella norma ISO 22301 nel 2012.

La ISO 22301, pubblicata in Italia nel dicembre 2019 come UNI EN ISO 22301, è considerata il primo standard internazionale per la *Business Continuity*.

3. Definizione della Business Continuity

La *Business Continuity* è una disciplina fondata sul buon senso, risultante da un'attenta integrazione di sviluppi razionali; e si riferisce alla norma ISO 22301 "*Societal Security - Business Continuity Management Systems - Requirements*" che stabilisce i requisiti per un efficiente *Business Continuity Management System* (BCMS), applicabile a qualsiasi tipologia di organizzazione, a qualsiasi latitudine e di qualsiasi dimensione.

La *Business Continuity* è la capacità di un'azienda di mantenere l'erogazione di prodotti e servizi a un livello accettabile nonostante eventi avversi che potrebbero causare interruzioni, anche brevi, con conseguenti costi diretti e indiretti significativi, quali perdite di fatturato, quote di mercato, sanzioni e danni reputazionali.

La norma ISO 22301 si focalizza sullo sviluppo e il miglioramento continuo della resilienza aziendale, tenendo conto che le interruzioni possono essere causate da eventi catastrofici naturali, pandemie, sabotaggi, attacchi terroristici, turbolenze di mercato, crisi economiche e geopolitiche, guasti tecnici, attacchi informatici, interruzioni di corrente, incendi e problemi nella *supply chain*.

Tali eventi possono provocare fermi operativi o addirittura portare alla chiusura definitiva di

un'organizzazione. Di conseguenza, le aziende devono proteggersi contro tali minacce in un contesto sempre più incerto, complesso, globalizzato e digitalizzato.

Attraverso l'implementazione dei principi di *Business Continuity*, un'organizzazione diventa consapevole delle potenziali situazioni avverse e si prepara a gestirle, assicurando la continuità dei processi e delle attività essenziali per fornire prodotti e servizi critici, nonché ripristinandoli dopo eventuali interruzioni.

La norma ISO 22316 "*Security and Resilience*" definisce la Resilienza Organizzativa come la capacità di un'organizzazione di assorbire gli shock e adattarsi a un contesto in continuo cambiamento.

4. ISO 22301 – Business Continuity Management System (BCMS)

Ogni organizzazione è unica e può integrare la disciplina della *Business Continuity* in modi diversi, tenendo conto di vari fattori come le dimensioni dell'organizzazione, i Paesi in cui opera, la cultura aziendale, il settore di attività e le risorse disponibili.

4.1. Business Continuity Plan (BCP) resilienti: come progettarli?

I gestori della *Business Continuity* sviluppano i *Business Continuity Plan* (BCP) per garantire il ripristino delle operazioni dopo incidenti o crisi, concentrandosi sul ritorno alla normalità.

Tuttavia eventi come il Covid-19, le crisi geopolitiche e geoeconomiche o gli eventi atmosferici estremi hanno evidenziato la necessità di adattare questi piani a cambiamenti radicali nella domanda e nei modelli operativi, richiedendo modifiche strategiche e ottimizzazione dei costi. I BCP devono essere integrati con l'intera organizzazione e allineati al processo decisionale strategico per gestire nuovi paradigmi senza difficoltà.

È fondamentale sincronizzare i processi di *Business Continuity* con quelli di gestione del ri-

schio strategico e operativo, coinvolgendo i *Business Continuity Manager* nel processo decisionale per adattare il piano alle esigenze emergenti.

Sebbene la certificazione ISO 22301 non sia obbligatoria, molte organizzazioni adottano i suoi principi per garantire la resilienza. La certificazione, valida per tre anni con verifiche annuali, è rilasciata da un Organismo di Certificazione indipendente che valuta l'implementazione del sistema di gestione.

Esaminare la ISO 22301 passo dopo passo aiuta a comprendere come applicare i suoi principi nelle organizzazioni. Vediamo di cosa si tratta.

4.2. La ISO 22301

La ISO 22301:2019, primo Standard realmente accettato a livello internazionale sulla *Business Continuity*, si articola come segue:

- 1.** Introduzione
- 2.** Ambito
- 3.** Riferimenti normativi
- 4.** Termini e definizioni
- 5.** Contesto dell'organizzazione
- 6.** Leadership
- 7.** Pianificazione
- 8.** Supporto
- 9.** Attività Operative
- 10.** Valutazione delle prestazioni
- 11.** Miglioramento.

4.3. Punti da “0” a “3”

Queste sezioni forniscono un background dello standard, illustrando come dovrebbe essere compreso e applicato (ad esempio Premessa, Introduzione, Scopo e Campo di Applicazione, Riferimenti Normativi, Terminologia).

4.4. Punti da “4” a “10”

Le seguenti sezioni stabiliscono gli obiettivi della norma, ovvero **chiarire i risultati della Business Continuity per:**

- Permettere alle organizzazioni di proteggersi e ridurre la probabilità di incidenti, crisi, o interruzioni, preparandosi a rispondere e recuperare attraverso l'implementazione e il miglioramento continuo di un *Business Continuity Management System* (BCMS).
- Stabilire i tempi di ripristino e progettare i piani.
- Mitigare il rischio associato a incidenti, crisi o interruzioni.
- Assicurare che i processi e le risorse siano recuperabili e ripristinabili per soddisfare le aspettative delle parti interessate riguardo alla fornitura di prodotti e servizi.

Garantire focus e allineamento strategico per:

- Concentrarsi sui prodotti e servizi più importanti e critici per l'organizzazione.
- Assicurare l'allineamento con gli obiettivi e obblighi organizzativi.

Coinvolgere il Top Management per:

- Ottenere il supporto e coinvolgimento nella definizione degli obiettivi del BCMS.
- Garantire l'adeguata e continua allocazione delle risorse necessarie, insieme al miglioramento continuo, in risposta ai cambiamenti nell'ambito di applicazione e ai risultati della misurazione delle prestazioni.
- Assicurare una maggiore integrazione con il *Risk Management* per rispondere alle esigenze e obblighi legali, normativi e contrattuali.

Analizziamo ora alcuni punti strategici della ISO 22301, fondamentali per l'avvio del BCMS.

4.5. Punto 3.0 - Termini & Definizioni

Tra i principali termini e definizioni ricordiamo:

- **Business Continuity (BC)** - la capacità di un'organizzazione di continuare a fornire servizi e prodotti a un livello accettabile dopo un evento destabilizzante.
- **Business Continuity Management System (BCMS)** - il sistema di gestione che stabilisce, implementa, gestisce, monitora, revisiona, mantiene e migliora la *Business Continuity*. Come definito dal DRI (*Disaster Recovery Institute*), è un processo di gestione che identifica i rischi, le minacce e le vulnerabilità che potrebbero influenzare la continuità delle attività, fornendo un metodo per costruire la resilienza organizzativa e la capacità di rispondere efficacemente agli incidenti.
- **Business Impact Analysis (BIA)** - è un processo fondamentale per valutare le attività critiche di un'organizzazione e comprendere l'effetto che un'interruzione operativa potrebbe avere su di esse.
- **Crisi** - si tratta di una situazione caratterizzata da un elevato livello di

incertezza che compromette le attività principali e/o la credibilità di un'organizzazione. In tale contesto, è necessario intraprendere azioni urgenti per mitigare i rischi e ripristinare la normalità operativa.

- **Incidente** - si tratta di una situazione che potrebbe costituire, o portare a, un'interruzione delle attività, una perdita, un'emergenza o una crisi.
- **Informazioni Documentate** - il riferimento è a tutte le informazioni che un'organizzazione deve periodicamente controllare e aggiornare, specificando anche come vengono archiviate. In un contesto di revisione e/o certificazione, è fondamentale dimostrare le azioni intraprese attraverso documentazioni quali: verbali di riunioni, procedure, registri di formazione e risultati scaturiti da test ed esercitazioni di continuità.
- **Maximum Acceptable Outage (MAO)** - è il tempo massimo considerato accettabile durante il quale un prodotto o servizio non viene fornito, o un'attività non viene svolta, a causa di un evento avverso.
- **Maximum Tolerable Period of Disruption (MTDP)** - è il tempo massimo che può trascorrere considerando gli impatti negativi derivanti da un incidente, come la mancata fornitura di un prodotto, la mancata erogazione di un servizio o il mancato svolgimento di un'attività operativa. È importante notare che il MTDP può essere più lungo del MAO, poiché gli effetti negativi di un'interruzione possono perdurare oltre la durata dell'interruzione stessa.
- **Minimum Business Continuity Objective (MBCO)** - è il livello minimo di servizi o di prodotti che un'organizzazione considera accettabile per raggiungere i propri obiettivi operativi durante un'interruzione.
- **Business Continuity Plan (BCP)** - si tratta dello sviluppo di un piano attuabile per prepararsi a probabili eventi di crisi, garantire la sicurezza del personale e riprendere le operazioni aziendali dopo un incidente.
- **Recovery Point Objective (RPO)** - è il punto temporale in cui le informazioni sono coerenti e possono essere ripristinate per consentire la

ripresa delle attività. È spesso denominato *Maximum Data Loss* e solitamente coincide con l'ultimo *backup* dei dati.

- **Recovery Time Objective (RTO)** - indica il tempo entro il quale i servizi, la produzione, i servizi di supporto e le funzionalità operative devono essere ripristinati dopo un incidente che abbia causato discontinuità.

4.6. Perché è importante implementare un BCMS?

I vantaggi dell'implementazione di un BCMS sono molteplici; di seguito, a titolo esemplificativo, se ne evidenziano i principali.

Migliore performance dei processi, grazie a:

- mappatura accurata dei processi aziendali;
- riconoscimento dei processi fondamentali per l'attività aziendale;
- individuazione di strategie per il recupero dei processi;
- abilità di rispondere prontamente grazie a procedure operative precise e specifiche;
- definizione dei team con ruoli e responsabilità ben delineati e membri adeguatamente formati.

Migliore posizionamento competitivo, grazie a:

- impatto positivo sui clienti, garantito da una maggiore affidabilità nella fornitura;
- ottimizzazione dell'offerta per specifici segmenti di mercato;

- crescente capacità di affrontare nuovi mercati con resilienza;
- miglioramento del *rating* di rischio per l'accesso al credito e maggiore attrattiva per i fondi di investimento;
- riduzione dei costi assicurativi.

Ulteriori benefici in termini di:

- maggiore sicurezza e migliore gestione del personale in caso di interruzioni dell'operatività;
- riduzione dei costi in caso di interruzioni dell'operatività;
- migliore gestione della crisi vs. interlocutori interni ed esterni, attraverso pianificazione della comunicazione esterna e interna;
- duplicazione delle risorse per prevenire perdite di dati.

5. Le fasi della Business Continuity

Da dove iniziare?

Chi ben comincia è già a metà dell'opera: per avviare efficacemente la pianificazione della *Business Continuity* è importante seguire un percorso strutturato e sequenziale, come indicato dalla ISO 22301 e da linee guida internazionali quali le *BCI* (Business Continuity Institute) *Good Practices Guideline* (GPG) e le *DRI* (Disaster Recovery Institute) *Guidelines*.

Lo standard ISO 22301 afferma l'importanza non solo di avere un piano, ma anche di implementare un BCMS.

Grazie all'approccio PDCA (*Plan-Do-Check-Act*) è possibile creare una cultura organizzativa che guidi il miglioramento continuo attraverso misurazioni e feedback ripetitivi delle prestazioni, come evidenziato graficamente dalla figura che segue.

Grazie all'approccio basato su sistemi di gestione, è possibile esercitare un lavoro di applicazione e coordinamento attraverso un approccio multidisciplinare.

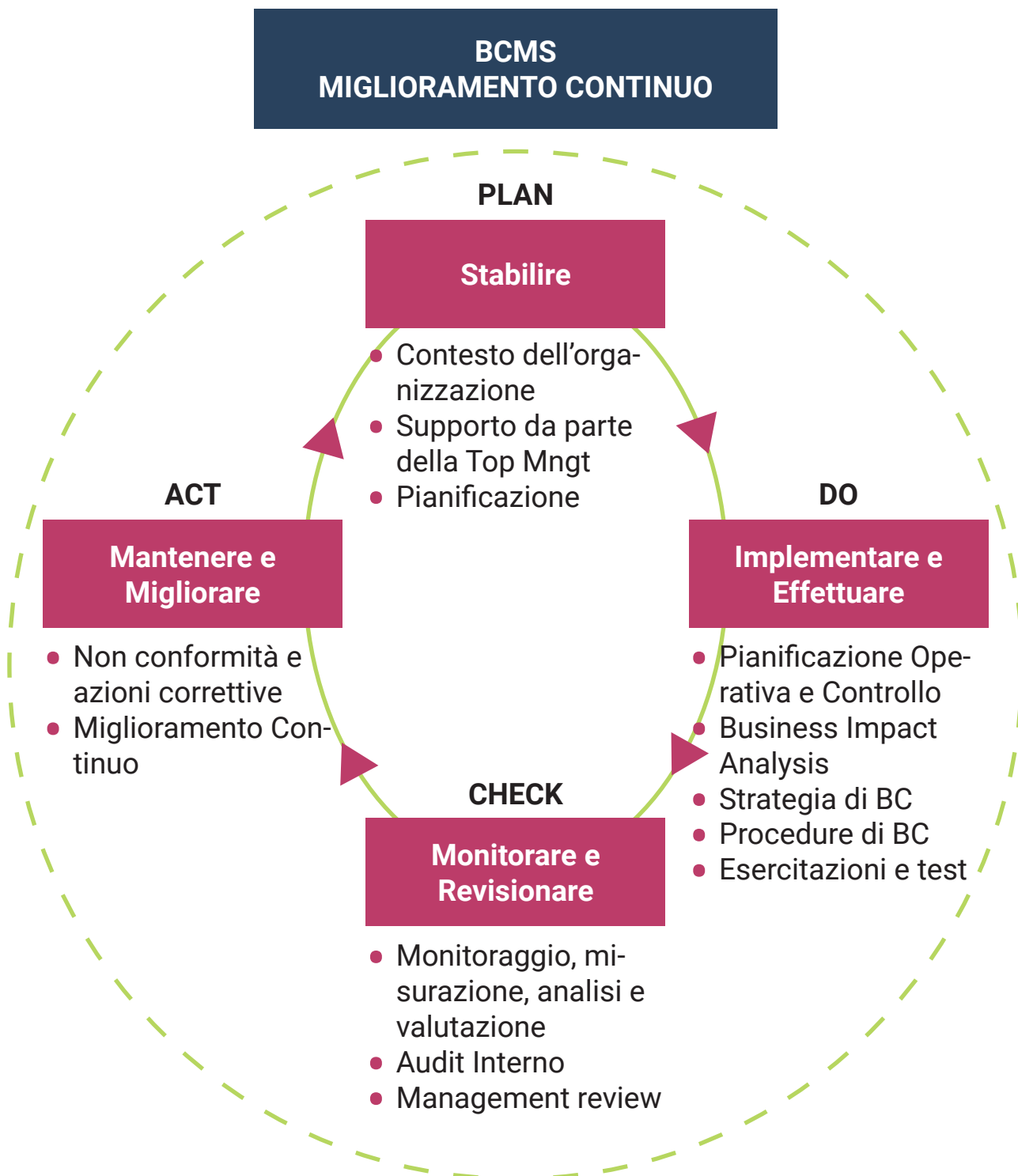


Immagine creata da Federica Maria Rita Livelli

I sistemi di gestione forniscono processi fondamentali per raggiungere un obiettivo comune di *Business Continuity*, che è mitigare il rischio associato alla *Business Continuity* stessa. Ciò include la protezione delle attività e delle risorse critiche che forniscono i prodotti e i servizi essenziali dell'organizzazione.

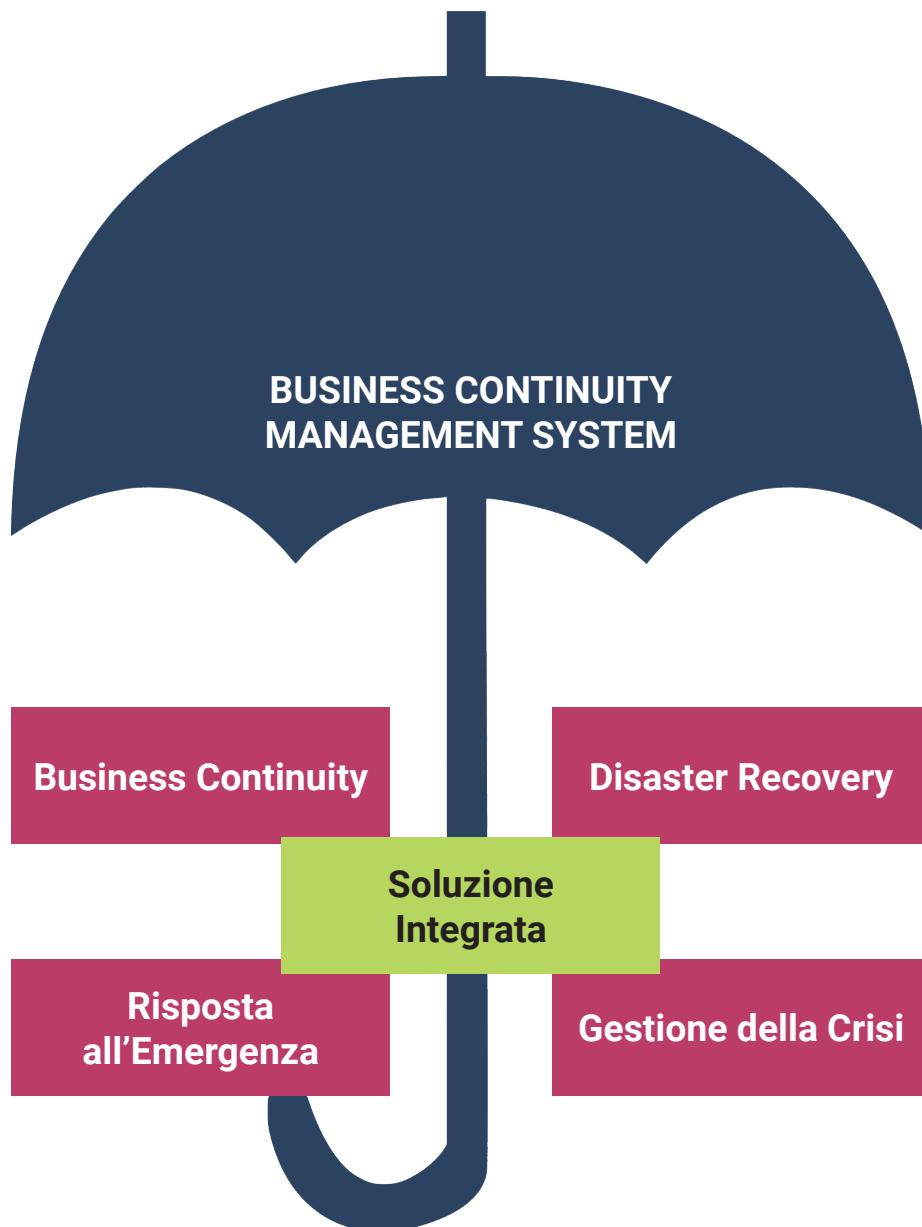


Immagine creata da Federica Maria Rita Livelli

I sistemi di gestione aggiungono valore perché, grazie alla loro progettazione, permettono a un'organizzazione di soddisfare simultaneamente diversi standard, requisiti normativi e

altri obblighi mediante un unico sistema di gestione. Questo rende il *Business Continuity Management* simile a un ombrello, che copre e integra vari aspetti della gestione aziendale per garantire la *Business Continuity* e la resilienza organizzativa.

Non dimentichiamo che le organizzazioni hanno spesso più fonti di requisiti che influenzano l'esecuzione delle attività di pianificazione.

In questo modo, gli standard di gestione – come l'ISO 22301 – possono aiutare a implementare un sistema di gestione che funge da “ombrello”, ovvero un sistema che è in grado di soddisfare in modo flessibile le esigenze di *Business Continuity* di ogni organizzazione; mentre gli altri sistemi, seguendo un approccio armonizzato (i.e. *Harmonized Structure* - HS) tipico di tutti i sistemi di gestione, sono in grado di aggiungere attività di pianificazione e soluzioni di supporto al sistema di gestione della *Business Continuity*.

Il primo passo da compiere, secondo l'ISO 22301, è descritto nel Punto 4.

5.1. Punto 4 – Conoscere il contesto

Le organizzazioni, per implementare efficacemente un *Business Continuity Management System* (BCMS), devono seguire un percorso che ricorda la massima dell'Oracolo di Delfi, “*Conosci te stesso*”.

Ciò implica:

- **Conoscere il contesto** - si tratta acquisire una profonda conoscenza e consapevolezza di sé, sia come entità che come insieme di persone, nonché del contesto interno ed esterno in cui si opera.
- **Identificare i bisogni dell'organizzazione e delle sue parti interessate** - è fondamentale raccogliere documentazione utile per identificare le priorità e i requisiti organizzativi e definire l'ambito del BCMS. Ciò include documenti interni sulla *mission* e la strategia, report annuali, descrizioni di prodotti o servizi e rapporti commerciali con terze parti, quali fornitori e clienti.

- **Confrontarsi con la Leadership** - tale passaggio serve a verificare la validità della documentazione e apportare modifiche necessarie riguardo alla missione, strategia, previsioni e obiettivi di crescita. Inoltre, aiuta a comprendere le priorità dell'organizzazione e il suo grado di tolleranza al rischio, oltre a definire i prodotti e i servizi da includere nel BCMS.
- **Definire l'approccio al rischio da parte dell'organizzazione** - l'organizzazione deve comprendere il proprio grado di esposizione al rischio in relazione alla *Business Continuity*, riferendosi alla ISO 31000 ("*Risk management – Principles and guidelines*").

NOTA: Se un'organizzazione si avvicina per la prima volta alla *Business Continuity*, è consigliabile iniziare concentrandosi sui processi, prodotti e servizi di massima criticità. Con l'evoluzione e la maturità del BCMS, è possibile aggiungere ulteriori processi, prodotti e servizi.

Indipendentemente dal numero di processi, prodotti e servizi critici identificati, è cruciale individuare le funzioni e i responsabili più appropriati per le attività di valutazione e di sviluppo della strategia.

Tale approccio garantisce una gestione efficace dell'implementazione del BCMS, consentendo il miglioramento continuo e/o l'ampliamento del sistema nel tempo.

5.2. Punto 5.0 – Leadership

Il punto 5.0 definisce chiaramente il ruolo della *Leadership* all'interno del BCMS.

Il *Top Management* deve adoperarsi per assicurare che le attività di *Business Continuity* siano in linea con le strategie dell'organizzazione. Ciò include non solo l'allineamento strategico, ma anche il supporto attivo e continuo necessario per garantire il successo del BCMS.

La Leadership deve quindi impegnarsi a fornire le risorse, la guida e l'attenzione necessarie per implementare efficacemente il BCMS e promuovere una cultura di resilienza all'interno dell'organizzazione.

La ISO 22301 stabilisce che la Leadership o il *Top Management* sono responsabili di diversi aspetti cruciali per il BCMS, tra cui:

- definizione della politica e degli obiettivi di *Business Continuity*;
- assegnazione di ruoli e responsabilità;
- fornitura delle risorse necessarie per l'implementazione del BCMS;
- comunicazione dell'importanza del BCMS;
- garanzia dei risultati previsti dal BCMS;
- promozione del miglioramento continuo.

È essenziale definire chiaramente la policy di *Business Continuity*, promuoverla all'interno dell'organizzazione e stabilire aspettative e ruoli chiari per coloro che partecipano al processo di pianificazione.

Per gestire efficacemente il BCMS, è importante costituire un *Business Continuity Steering Committee* (BCSC) o un team simile, composto da rappresentanti della *Leadership*.

La selezione di leader senior adeguati a questo comitato è strategica per ottenere il consenso e il coinvolgimento dell'intera organizzazione. Di fatto, un comitato ben composto permette di definire criteri, ruoli e prestazioni della pianificazione della *Business Continuity* in linea con le esigenze dell'organizzazione.

Lo *Steering Committee* ha il compito di raccogliere informazioni dalle varie funzioni aziendali per implementare i principi di *Business Continuity*. Inoltre è responsabile della supervisione del BCMS, contribuendo a:

- fornire il supporto necessario alla continuità operativa;
- assegnare le risorse necessarie per raggiungere gli obiettivi di *Business Continuity*;
- definire l'ambito del BCMS, identificando le unità aziendali o divisioni da rappresentare;

- assicurare che gli interessi dell'organizzazione siano considerati adeguatamente;
- ottenere feedback dall'organizzazione;
- comunicare internamente l'importanza della partecipazione al BCMS.

Il BCSC – una volta costituito – provvederà a:

- **creare una policy di *Business Continuity*** che delinei le aspettative del top management riguardo alla Business Continuity, includendo i seguenti aspetti.
 - » L'ambito, ovvero l'identificazione di prodotti e servizi critici e delle aree organizzative coinvolte.
 - » Gli obiettivi di prestazione legati alla Business Continuity.
 - » Le metriche e i parametri per valutare e riferire le prestazioni alla Leadership.
 - » Il miglioramento continuo del BCMS.
 - » La definizione di ruoli e responsabilità, che coinvolgono la Leadership e i vari attori dell'organizzazione.
- **Stabilire ruoli e responsabilità necessari per implementare il BCMS** in base alla struttura dell'organizzazione e in modo da conseguire gli obiettivi prefissati. I ruoli più comuni sono quello dello sponsor e del coordinatore, che dovranno riflettere precise caratteristiche.
 - » Lo Sponsor di Business Continuity: funzione generalmente svolta da un dirigente senior o un membro della proprietà aziendale, che detiene la responsabilità globale delle prestazioni di Business Continuity ed è in grado di prendere decisioni per implementare e migliorare il BCMS, facilitando l'integrazione della Business Continuity nella cultura aziendale.

- » Il Coordinatore/Manager di Business Continuity: figura responsabile per la supervisione della pianificazione della Business Continuity, assicurando che venga rispettata. Inoltre, è incaricata di eseguire il BCMS secondo le direttive del BCSC.

5.3. Punto 6.0 – Pianificazione

Si tratta di pianificare l'implementazione del BCMS in base ai requisiti dell'organizzazione e all'ambito definito nel Punto 4.0 (i.e. Contesto), predisponendone la struttura in linea con la strategia e la cultura dell'organizzazione, in modo da definire anche gli obiettivi in grado di soddisfare le aspettative e consentire la misurazione delle prestazioni.

Innanzitutto, si deve:

- **Definire gli obiettivi del BCMS**, attività essenziale che comporta considerare l'ambito delineato, la policy di *Business Continuity* e le aspettative e i requisiti di tutte le parti coinvolte. Il coordinamento con il BCMS è cruciale per condividere questi obiettivi con chi è responsabile dell'esecuzione del ciclo di vita della *Business Continuity*. È altresì importante che gli obiettivi siano adeguati, monitorabili, comunicati efficacemente e aggiornati quando necessario.

Esempi di obiettivi di un'organizzazione includono: proteggere la sicurezza di dipendenti e visitatori nelle sedi aziendali; gestire le minacce e gli impatti delle interruzioni nei processi critici, come interruzioni strutturali o perdite di risorse (personale, tecnologie, partner commerciali).

- **Allinearsi e integrarsi con le modalità di *risk management***, in modo da garantire la predisposizione di un BCMS più efficace ed efficiente, utilizzando le valutazioni dei rischi già disponibili per scegliere le migliori soluzioni. Un approccio sinergico con la funzione di *risk management* è essenziale, creando un sistema di gestione unificato in cui il rischio è attribuito a ciascun responsabile (i.e. *risk owner*).

- **Allinearsi e integrarsi con la cultura organizzativa**, tenendo conto delle risorse disponibili, sia centralizzate sia periferiche. È essenziale, inoltre, identificare il modo migliore per incorporare la *Business Continuity* nelle operazioni quotidiane, nella gestione dei progetti e nelle eventuali modifiche organizzative, normative e di contesto.

Ricordiamo che, per il successo del BCMS, è strategico definire chiaramente gli obiettivi e comunicare efficacemente i risultati a tutti i soggetti coinvolti nel processo.

5.4. Punto 7.0 – Supporto

Il Punto 7.0 si concentra sull'assegnazione delle risorse necessarie per implementare, mantenere e migliorare il BCMS.

Pertanto, per raggiungere questi obiettivi, è fondamentale:

- **Definire le competenze del personale addetto alla *Business Continuity***, ovvero identificare le conoscenze ed esperienze necessarie per pianificare, rispondere e garantire il recupero da incidenti o crisi. È essenziale prevedere una formazione ad hoc per colmare eventuali lacune.
- **Garantire la diffusione e la consapevolezza della politica di *Business Continuity* all'interno dell'organizzazione**, ossia assicurarsi che tutto il personale comprenda il proprio ruolo e contribuisca al successo del BCMS, soddisfacendo le aspettative dell'organizzazione.
- **Garantire la comunicazione efficace**, predisponendo un piano di comunicazione per il BCMS rivolto a stakeholder interni ed esterni, che includa messaggi efficaci pre, durante e post incidente/crisi/interruzione.
- **Garantire un elenco completo della documentazione di BCMS** che includa attività, documentazione approvata, comunicazioni e risultati raccolti.
- **Definire la gestione della documentazione del BCMS**, specificando le

modalità di raccolta, gestione, accesso, conservazione e protezione della documentazione.

Un corretto approccio prevede l'implementazione di un'ulteriore serie di attività, quali:

- **Predisposizione di Procedure Operative Standard** (*Standard Operating Procedures* - SOP) che definiscono le azioni da intraprendere per mitigare l'impatto di eventi sull'operatività aziendale.
- **Predisposizione di un programma di valutazione e di sviluppo delle competenze**, coinvolgendo tutto il personale del BCMS, incluso chi partecipa alla pianificazione della risposta e del recupero. Il programma deve periodicamente identificare le competenze necessarie e fornire opportunità di sviluppo per colmare eventuali lacune; ciò include l'analisi del profilo delle risorse coinvolte nel BCMS per garantire che comprendano il loro ruolo, oltre a verificare che siano idonee, disposte e capaci di svolgerlo. È fondamentale valutare le competenze, come titoli di studio, conoscenze, esperienze, abilità e formazione, nonché assicurare chiarezza sulle responsabilità.
- **Predisposizione di un piano di comunicazione relativo al BCMS implementato**, atto ad informare le parti interessate e contenente:
 - » **Messaggi chiave** rivolti a tutte le parti interessate, ovvero stakeholder interni (personale, CdA, Team di risposta/recupero) ed esterni (clienti, fornitori, partner; istituzioni, organizzazioni locali e governative, forze dell'ordine e di soccorso).
 - » **Modalità di trasmissione**, specificando come, quando e da chi i messaggi saranno trasmessi.

Si ricorda che tali comunicazioni dovranno essere calibrate a seconda della tipologia di destinatari.

Inoltre è necessario predisporre le procedure di gestione della documentazione di BCMS, per controllare le varie versioni dei documenti e conservare quelli strategici per garantire la disponibilità dell'ultima versione approvata, relativamente alla pianificazione e alle modalità di risposta e ripristino in caso di incidenti o crisi.

5.5. Punto 8.0 – Attività Operative (Operation)

Il Punto 8.0 è cruciale poiché riguarda l'implementazione e il mantenimento delle attività necessarie per soddisfare le aspettative della *leadership*, ovvero la *Business Impact Analysis* (BIA) e il *Risk Assessment* (RA); le strategie e le soluzioni di Business Continuity; i piani e le procedure; la programmazione delle esercitazioni e dei test; la valutazione della documentazione e dell'efficacia del BCMS.

In questa fase si identificano le attività necessarie per proteggere l'organizzazione e le parti interessate, minimizzando la probabilità e l'impatto di un incidente o crisi e riducendo i tempi di inattività.

Di seguito si esaminano in dettaglio queste attività e i vari step per la loro implementazione.

6. La BIA

La BIA si prefigge di determinare i requisiti di *Business Continuity* fornendo informazioni atte a identificare le soluzioni più idonee. Inoltre, questa fase include l'identificazione delle dipendenze delle risorse di supporto e la definizione dei *Recovery Time Objective* (RTO).

Lo scopo della BIA è, di fatto, mappare e stabilire le priorità dei prodotti e dei servizi critici e strategici, che devono essere protetti e ripristinati rapidamente in caso di interruzioni.

Si tratta anzitutto di fornire un inventario delle attività e delle risorse aziendali, per identificare ciò che deve essere protetto o ripristinato a seguito di eventuali interruzioni o crisi.

Inoltre, stabilire gli obiettivi di RTO aiuta l'organizzazione a determinare il tempo entro il quale recuperare risorse e riattivare i processi, le attività, i servizi e i prodotti. Si tratta, quindi, anche di stabilire le priorità delle opzioni di trattamento del rischio nonché le strategie di risposta e di recupero, consentendo il raggiungimento degli obiettivi strategici dell'organizzazione.

È importante, altresì, stabilire gli obiettivi di RPO per determinare il punto in cui i dati devono essere recuperati per permettere il ripristino. Va ricordato che l'RPO è noto anche come la massima perdita di dati, che coincide con l'ultimo *backup*.

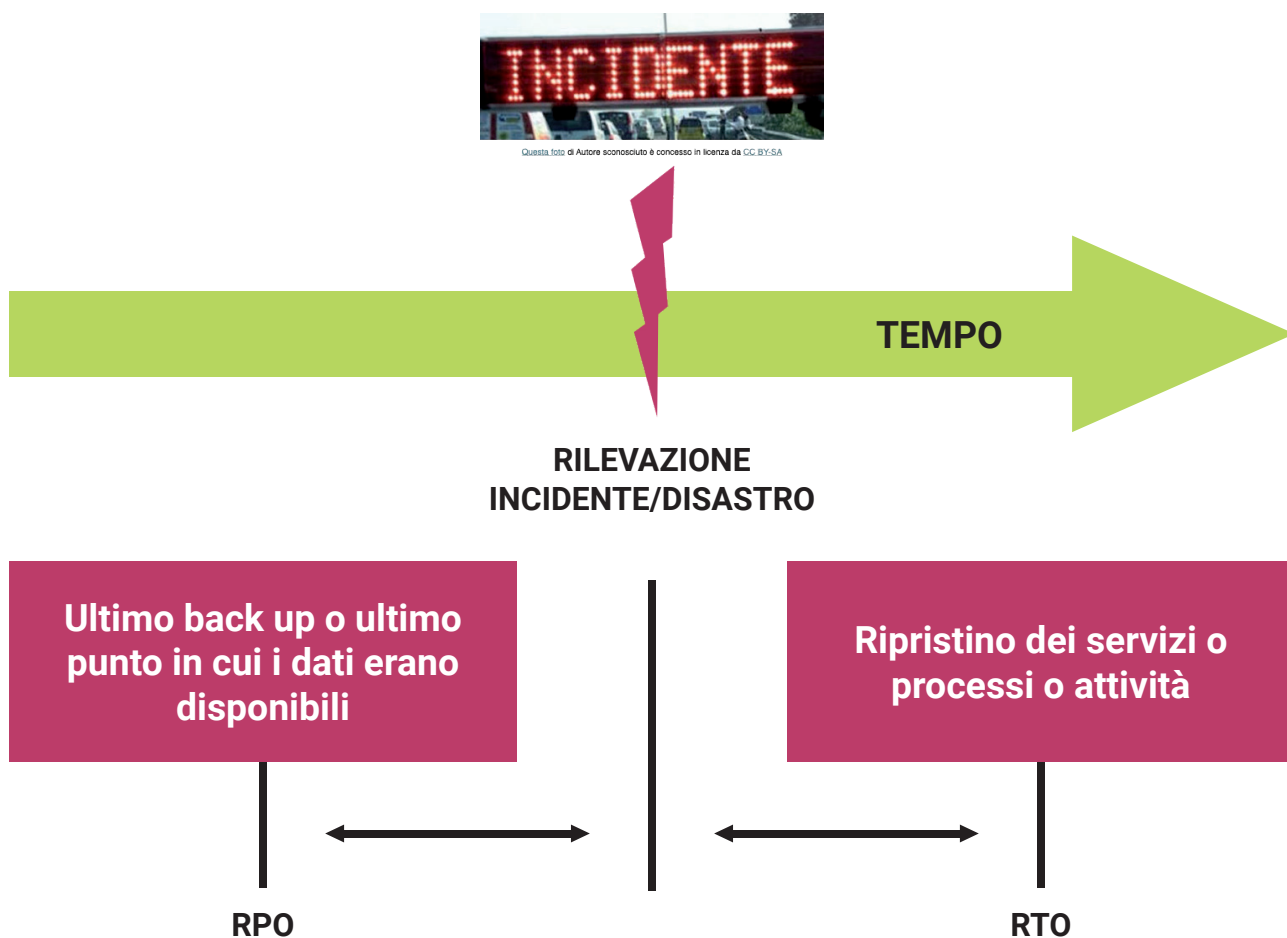


Immagine creata da Federica Maria Rita Livelli

Inoltre, grazie alla BIA, un'organizzazione è in grado di:

- **Confermare la validità dell'ambito del programma di *Business Continuity*** in termini di attività e risorse aziendali necessarie per sostenere i processi, prodotti e servizi più critici e strategici. Ciò permette all'organizzazione di verificare se ci sono processi, prodotti e servizi inizialmente non considerati ma che risultano strategici in caso di interruzione.; in tal modo l'organizzazione può riesaminare l'ambito, identificando quali processi, prodotti e servizi devono essere inclusi e

quali risorse devono essere considerate, poiché possono influenzare il programma di *Business Continuity*.

- **Identificare e comprendere gli obblighi legali, regolamentari e contrattuali** in modo da garantire un'adeguata pianificazione della *Business Continuity* in termini di conformità.
- **Avere una chiara visibilità dei costi di implementazione della strategia di *Business Continuity*** a fronte della stima degli impatti (finanziari, reputazionali, contrattuali, normativi, operativi, ecc.) correlati ai tempi di interruzione, al fine di poter giustificare in modo documentato la selezione, l'implementazione e il mantenimento della strategia atta conseguire gli obiettivi di recupero.
- **Raccogliere i dati propedeutici alla stesura dei Piani di *Business Continuity*** in termini di: controlli esistenti; strategie di ripristino; requisiti in termini di team e personale; informazioni di contatti interni ed esterni; altre informazioni riferite alle specifiche risorse necessarie per il BCP.

Dopo aver raccolto queste informazioni, l'organizzazione – o, meglio, coloro che al suo interno sono incaricati di creare e mantenere il BPC – possono procedere a redigerlo.

La BIA si occupa di definire i requisiti di *Business Continuity*, identificare le dipendenze dalle risorse e convalidarle rispetto agli impatti stimati dei tempi di inattività.

D'altro canto, il RA si concentra sulla comprensione della probabilità e della gravità delle perdite di attività e di risorse, con l'obiettivo di stabilire un elenco prioritario di trattamenti del rischio per prevenire interruzioni nella capacità dell'organizzazione di fornire prodotti e servizi.

6.1. Da dove iniziamo ad eseguire una BIA?

Solitamente, per avviare la fase della BIA, si esegue un iter strutturato come segue.

- **Meeting iniziale con la *Leadership***, per:
 - » determinare le esigenze di *Business Continuity*, definendo il perimetro iniziale;
 - » stabilire chi parteciperà al programma di BC;
 - » preparare un primo cronoprogramma delle attività con il personale coinvolto.
- ***Kick-off meeting*** propedeutico a:
 - » allineare i partecipanti agli obiettivi del programma di BC con il supporto della *leadership*;
 - » presentare il programma delle attività di BIA;
 - » presentare la mappatura iniziale dei prodotti e servizi inclusi nel perimetro del programma di BC;
 - » illustrare le modalità di svolgimento della BIA e la documentazione di supporto. Le modalità includono: workshop (acquisizione rapida di informazioni da individui e team per aumentare la sensibilizzazione e integrare la *Business Continuity*); questionari (raccolta di informazioni dettagliate da singoli o team su supporto cartaceo o elettronico, generando una grande quantità di dati); interviste (acquisizione di informazioni di alta qualità, sebbene richiedano tempo, utili per discutere attività ordinarie, necessità di risorse, obblighi e possibili impatti di eventuali incidenti sulla capacità di erogare processi e servizi).

Di seguito si fornisce un esempio di come si possano strutturare le interviste di BIA.

Programmazione delle interviste di Business Impact Analysis (BIA), con:

- **Responsabili di ciascun Dipartimento/Funzione**, che devono dimostrare di avere una comprensione chiara delle priorità chiave dell'organizzazione in termini di prodotti e servizi e una conoscenza approfondita delle attività

quotidiane svolte all'interno del Dipartimento/Funzione, unitamente alle dipendenze delle risorse richieste per lo svolgimento di ogni attività.

- **Figure tecniche/esperti necessari.**

NOTA: risulta strategico e propedeutico per il successo della riunione/intervista far precedere una comunicazione/invito che descriva lo scopo della BIA, gli obiettivi che ci si prefigge di raggiungere e come prepararsi ad essa.

L'esecuzione delle interviste di BIA e il RA

Interviste BIA: mirano a determinare i processi e le attività svolte dal dipartimento che supportano la fornitura di quei processi, prodotti e servizi critici/strategici rientranti nel perimetro del programma di *Business Continuity*.

Per ogni processo o attività identificata è fondamentale raccogliere informazioni sulla modalità di esecuzione, censendo applicazioni, attrezzature, strutture utilizzate, fornitori, personale dedicato e relativi *backup*, se presenti. È inoltre necessario identificare e descrivere le dipendenze di ciascun processo o attività, individuando potenziali soluzioni alternative (come soluzioni manuali o fornitori alternativi, in caso di perdita o interruzione delle dipendenze critiche) e definire gli obiettivi di RTO.

È altresì importante e utile effettuare un RA per valutare la probabilità di perdita per ciascuna dipendenza. Inoltre, è essenziale conoscere i periodi di picco delle operazioni, i periodi di inattività, le chiusure e le manutenzioni. Bisogna anche identificare i vari impatti dei tempi di inattività, come quelli finanziari, operativi, strategici, ambientali, normativi e reputazionali, valutando altresì come questi impatti si evolvano nel tempo. Infine, è utile raccogliere informazioni sugli eventi passati che hanno avuto un impatto significativo sull'organizzazione.

RA: consente all'organizzazione di identificare e descrivere il rischio associato a interruzioni specifiche, determinando la probabilità di interruzione dei processi e delle attività per la creazione o fornitura di prodotti e servizi nell'ambito del programma di *Business Continuity*, basandosi su una revisione dei controlli progettati per proteggere le risorse chiave come strutture, personale, attrezzature, tecnologia dell'informazione, dati e fornitori o partner commerciali. Inoltre il RA aiuta a identificare le potenziali cause o fonti di interruzione – comunemente chiamate minacce – e a raccomandare controlli per ridurre la probabilità o l'impatto delle interruzioni su processi, attività e risorse, tenendo conto dei potenziali costi di trattamento.

Di seguito la rappresentazione grafica dell'interazione tra *Risk Assessment & Business Impact Analysis*.

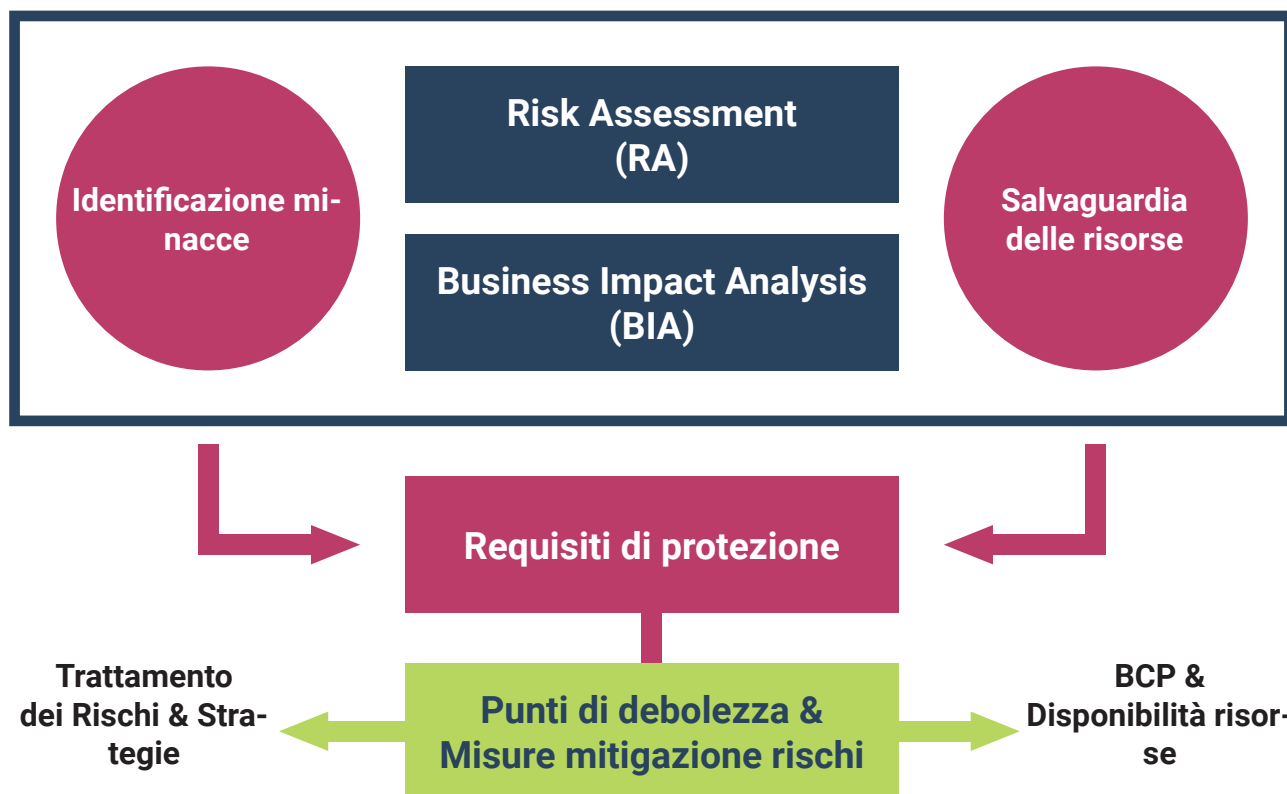


Immagine creata da Federica Maria Rita Livelli

6.2. Una domanda lecita: viene prima la Business Impact Analysis (BIA) o il Risk Assessment (RA)?

Si tratta di una domanda che è spesso oggetto di dibattito tra professionisti del settore.

È doveroso ricordare che la BIA e il RA sono due componenti fondamentali per garantire lo sviluppo di un efficace BCMS.

“Prima la BIA” - le organizzazioni possono iniziare con la BIA per identificare le funzioni aziendali critiche, seguita da un RA per analizzare e mitigare i rischi associati a ciascuna attività. Tale approccio consente di focalizzarsi su minacce specifiche per ogni unità azien-

dale. Nelle organizzazioni più grandi, identificare tutti i rischi può essere complesso; quindi iniziare con la BIA può risparmiare tempo e sforzi, dato che essa aiuta a determinare le risorse essenziali per la continuità del business, mentre il successivo RA identifica i rischi potenziali e sviluppa piani di mitigazione.

“Prima il RA” - un approccio alternativo prevede di condurre il RA per identificare minacce e rischi a livello organizzativo, prima di eseguire la BIA. Tale approccio permette di sviluppare misure di mitigazione necessarie e affrontare la BIA con una maggiore consapevolezza degli incidenti possibili e dei rischi a cui l'organizzazione è esposta. Di conseguenza, l'organizzazione sarà meglio preparata a focalizzarsi sulle conseguenze di tali incidenti durante la BIA. Inoltre, adottando un approccio basato sugli asset per la valutazione del rischio, sarà più semplice identificare tutte le risorse durante la BIA.

È doveroso ricordare che un efficace quadro di gestione della *Business Continuity* assicura che un'organizzazione possa continuare a fornire prodotti e servizi a un livello minimo accettabile, proteggendo al contempo gli interessi delle parti interessate.

La comprensione delle potenziali minacce e la definizione delle priorità di ripristino sono entrambe fondamentali per implementare un BCMS: di conseguenza, la decisione di eseguire prima la BIA o il RA dipende dalle preferenze e dalle circostanze specifiche. Entrambi i processi sono complementari e di pari importanza, contribuendo a valutare l'impatto potenziale di un'interruzione sull'organizzazione.

La *Business Continuity* si basa sull'analisi dei rischi e delle minacce per funzionare correttamente, concentrandosi sulla mitigazione degli impatti e sulla capacità di ripristino. Pertanto, senza la *Business Continuity*, il *Risk Management* manca di una misura fondamentale per mitigare l'impatto di un'interruzione. Il *Risk Management* si occupa di “trattare” i rischi, ovvero eliminarli quando possibile, ridurre la *magnitudo* delle conseguenze o la probabilità che si verifichino e trasferire a terzi le conseguenze finanziarie.

Predisposizione di un report finale delle interviste di BIA per ogni Dipartimento/Funzione

Il report finale delle interviste di *Business Impact Analysis* (BIA) include informazioni raccolte durante le interviste, requisiti di risorse, identificazione dei rischi e raccomandazioni basate sui dati raccolti, in particolare per quanto riguarda gli obiettivi di tempo di recupero (RTO) e la stima degli impatti. Tale report deve essere distribuito ai partecipanti delle interviste

per finalità di verifica, revisione, eventuali modifiche e approvazione, allo scopo di stabilire i requisiti di *Business Continuity* a livello organizzativo, che saranno poi esaminati e approvati dalla *Leadership* e/o dal *Top Management*.

Durante la presentazione dei risultati delle interviste di BIA per la convalida finale è necessario riesaminare i prodotti e servizi identificati e verificare che gli RTO per processi e attività siano allineati ai prodotti e servizi correlati, considerando i principali rischi insieme alle raccomandazioni su come affrontarli. I requisiti che l'organizzazione deve soddisfare e i rischi da mitigare per allinearsi agli RTO servono da input per lo sviluppo di strategie di *Business Continuity*.

Inoltre, se tali strategie risultano proibitive in termini di costi/benefici, dovranno essere riviste. Pertanto, la *Leadership* deve concentrarsi su come garantire il giusto livello di resilienza in conformità con gli obiettivi di *Business Continuity*, sviluppando strategie per gestire la perdita di attività e identificando le risorse necessarie.

6.3. Strategie & soluzioni di BC

Le BIA e il RA sono fondamentali per valutare le strategie e le soluzioni da implementare per continuare a operare dopo un'interruzione o crisi. È essenziale verificare l'allineamento dei risultati delle interviste di BIA e del RA con gli obiettivi iniziali di *Business Continuity*.

Pertanto è necessario **sviluppare strategie appropriate** per allinearsi ai requisiti, considerando i seguenti fattori.

- **Mitigazione del rischio:** ridurre la probabilità di interruzioni e limitare l'impatto.
- **Risposta agli incidenti:** definire un processo di risposta, predisponendo un team con figure di backup e procedure di valutazione e attivazione.
- **Recupero di attività e di risorse:** identificare risorse alternative per rispettare obblighi commerciali e normativi, come strutture, personale, attrezzature, IT e soluzioni manuali.

È inoltre essenziale **determinare le risorse necessarie** per implementare le strategie di Business Continuity, ovvero:

- **Stimare i costi di attuazione e mantenimento** delle strategie.
- **Includere tutte le risorse identificate nelle interviste di BIA**, necessarie in caso di interruzione, come persone, dati, strutture, attrezzature, trasporti e partner.
- **Considerare più opzioni strategiche**, valutando pro e contro e costi, per permettere alla *Leadership* di misurare gli investimenti rispetto alla propensione al rischio e selezionare la strategia più appropriata.

Infine, si devono **condividere con ogni Dipartimento/Funzione gli obiettivi e le raccomandazioni della strategia di Business Continuity** per feedback, selezione e approvazione.

Successivamente, la Leadership valuterà i costi-benefici di ogni strategia per determinare quella ottimale, sviluppando le procedure di *Business Continuity* corrispondenti.

Di seguito alcune tipologie di strategie di continuità.

Diversificazione: prevede la separazione di attività e risorse su due o più sedi, garantendo la continuità operativa in caso di interruzione in una di esse. È una soluzione costosa, ma adeguata quando l'RTO è di pochi minuti od ore.

Replica: la replica delle risorse è una variante della diversificazione che consente una rapida ripresa delle attività, mantenendo una sede duplicata con tutte le risorse pronte all'uso (*hot site*). È una soluzione adatta quando l'RTO è compreso tra alcune ore e giorni; il principale problema è trasferire il personale alla sede alternativa entro i rispettivi RTO delle attività.

Stand-by: prevede la disponibilità di una sede o stabilimento in *stand-by*, che può essere reso operativo nei tempi dell'RTO (*warm site*). Il principale problema, anche in questo caso, è trasferire il personale alla sede alternativa entro i rispettivi RTO delle attività.

Acquisizione post-incidente: quando gli RTO sono misurati in giorni o settimane, le organizzazioni possono considerare una soluzione di *Business Continuity* in cui le risorse necessarie vengono acquisite dopo l'interruzione. Ciò include un elenco predefinito e prioritario dei

fabbisogni di risorse e l'affidamento sui fornitori per consegnare le risorse – in termini di quantità e di qualità adeguate – entro tempi accettabili.

Non fare nulla: questo approccio è scelto quando l'RTO è espresso in settimane o mesi, oppure quando risulta impossibile o troppo costoso predisporre strutture e risorse alternative. È importante che il *Business Continuity Manager* o il professionista incaricato documenti sempre i motivi per cui si opta per questa soluzione, al fine di evitare controversie o conflitti in caso di incidente.

È doveroso evidenziare che alcune soluzioni e la relativa implementazione potrebbero richiedere il coinvolgimento delle competenze tecniche di esperti appartenenti ad altre aree di *expertise* o dipartimenti (i.e. specialisti in ICT, approvvigionamento/acquisti e rifornimenti, gestione delle scorte e pianificazione delle capacità di magazzino).

6.4. I BCP e Procedure di BC

Si tratta di predisporre una struttura di risposta, procedure di avviso e comunicazione, nonché piani di ripristino che costituiscano un processo ripetibile ed efficace, attivabile senza indugio in caso di incidente dirompente, interruzione o crisi.

I BCP devono essere redatti per:

- descrivere lo scopo e l'ambito del piano;
- delineare gli obiettivi di ripristino applicabili;
- documentare chiaramente i ruoli e le responsabilità del personale coinvolto nelle operazioni di risposta e recupero;
- identificare le dipendenze interne ed esterne;
- elencare i criteri per l'attivazione del piano;
- fornire modalità di risposta a un incidente dirompente e indicare come raggiungere gli RTO stabiliti per il ripristino e il ritorno alla normalità;

- dettagliare i requisiti in termini di risorse minime per il conseguimento dell'MBCO e di *reporting*.

Le procedure di *Business Continuity* fungono da supporto all'esecuzione dei BCP e, come tali, devono:

- fornire dettagli sulle misure specifiche, flessibili e adattabili, da implementare in caso di interruzione, definite in base ai requisiti della BIA e alle strategie di *Business Continuity*;
- identificare il responsabile della creazione e aggiornamento di ogni piano e delle relative procedure;
- descrivere una struttura di risposta coordinata ed efficiente per incidenti, crisi o eventi dirompenti, con criteri chiari per la risposta e il recupero, e decisioni che il Team di Risposta deve considerare, inclusi composizione, ruoli, attività, responsabilità e risorse;
- descrivere l'attivazione dell'Albero delle Chiamate e il monitoraggio degli incidenti;
- dettagliare le attività di ripristino e ritorno alla normalità;
- fornire modalità di avviso e comunicazione per facilitare la comunicazione con i soccorritori, ottenere informazioni dalle autorità competenti, identificare e monitorare le interruzioni e gestire le comunicazioni con tutte le parti interessate.

È importante ricordare che molte interruzioni richiedono l'attivazione di diversi piani di risposta per una gestione efficace. In un approccio olistico, il *Business Continuity Manager* deve collaborare con altri esperti come *Risk Manager*, *IT Manager*, *Security Manager*, *Facility Manager*, *HR Manager*, *Marketing Manager* e *Communication Manager*.

È altresì importante ribadire che il piano di BCP e le procedure di *Business Continuity* devono essere redatte in modo da essere efficaci, sintetiche e chiare, possibilmente utilizzando diagrammi di flusso. Questo è cruciale poiché, nei momenti critici, l'organizzazione deve essere in grado di rispondere all'interruzione e ripristinare l'operatività entro gli RTO approvati dalla *Leadership*.

Inoltre, le procedure non solo supportano la creazione delle competenze necessarie per la risposta e il recupero ma permettono anche di valutarne l'adeguatezza durante esercizi e test.

6.5. Esercizi & Test

Il miglioramento continuo di un BCP è fondamentale per un efficiente ed efficace BCMS. Ciò può essere ottenuto attraverso un programma di esercizi e di test delle strategie e delle procedure di *Business Continuity*, che permette di convalidare o rettificare nel tempo le capacità di risposta a un incidente dirompente entro gli RTO stabiliti dalla *Leadership*.

Esistono diverse modalità per eseguire esercizi e test, tra cui:

- **Esercitazioni basate sulla discussione** - sono la modalità più semplice e meno costosa, in cui i partecipanti esplorano questioni rilevanti e analizzano i piani attraverso modalità come il *walk-through*.
- **Esercitazioni di scenari** - basate sulla discussione di uno scenario definito nel tempo. Si tratta di esercitazioni realistiche ed economiche, che permettono di esercitare diverse fasi dello scenario in modalità *table-top*. Richiedono familiarità con i piani e comprensione del loro funzionamento.
- **Esercitazioni con simulazione** - si tratta di esercitazioni complesse e realistiche, che coinvolgono i partecipanti in simulazioni di incidenti reali, con ruoli assegnati e interazioni tramite telefonate o social media. Tali esercitazioni sono propedeutiche a verificare procedure come la notifica di un incidente e il coordinamento dei team.
- **Esercitazioni dal vivo** - utili in contesti caratterizzati da vincoli legali o normativi; tuttavia queste esercitazioni sono molto costose e possono comportare rischi fisici e reputazionali poiché, avvenendo dal vivo, richiedono una gestione complessa.

- **Test** - solitamente riguardano attrezzature, procedure di recupero, tecnologie o team, per valutarne l'efficacia operativa.

Prima di eseguire esercitazioni o test, l'organizzazione deve prepararsi garantendo:

- l'allineamento con l'ambito e gli obiettivi del BCMS;
- la fiducia e la conoscenza adeguata del personale coinvolto nel BCMS;
- l'utilizzo di scenari realistici e obiettivi chiaramente definiti, considerando che la complessità varia in base alla tipologia di esercizio o test;
- l'efficacia dell'intera strategia, delle soluzioni, dei piani e delle procedure del BCP;
- la minima interruzione delle normali operazioni durante gli esercizi e i test;
- la conduzione periodica di esercizi e test, specialmente in caso di cambiamenti significativi nell'organizzazione o nel contesto operativo;
- la produzione di report formalizzati che riassumano i risultati rispetto agli obiettivi, includendo raccomandazioni per il miglioramento continuo delle strategie e procedure di *Business Continuity*.

Per facilitare lo svolgimento di esercitazioni o test è consigliabile designare un facilitatore, che può essere interno all'organizzazione (come un professionista della *Business Continuity*) o esterno, come un consulente.

Inoltre, il facilitatore deve possedere eccellenti capacità di presentazione e comprovate capacità di *leadership*, oltre a un'esperienza adeguata nel formato di esercizio scelto. È fondamentale che abbia una conoscenza approfondita dell'organizzazione e/o del settore, nonché una sufficiente comprensione del BCMS dell'organizzazione, in particolare degli aspetti che vengono esercitati o testati.

6.6. Valutazione della documentazione e funzionalità della Business Continuity

Le valutazioni – effettuate tramite revisioni, analisi, esercizi, test, rapporti post-incidente ed esami delle prestazioni – devono considerare requisiti legali e normativi, *best practices* del settore e conformità alla policy di *Business Continuity*. Si tratta, altresì, di misurare la capacità di garantire la continuità da parte di partner e fornitori strategici.

A tal proposito, l'organizzazione deve identificare il metodo per la valutazione (i.e. revisioni formali o analisi interne/esterne) e stabilire criteri che considerino operazioni di altre organizzazioni del settore, nonché verificare la conformità normativa e le capacità di ripristino.

Deve inoltre identificare i fornitori principali per condurre una valutazione formale del loro programma di *Business Continuity*, assicurandosi che tutti abbiano un programma esercitato, documentato e aggiornato annualmente, che condividano la strategia di *Business Continuity* e che siano previste procedure alternative per eventuali interruzioni.

7. Punto 9 – Valutazione delle Prestazioni

In questa fase il professionista della *Business Continuity* verifica l'allineamento del BCMS ai requisiti di gestione e all'ISO 22301, oltre a valutare le prestazioni del BCMS e delle soluzioni di *Business Continuity* per fornire feedback e individuare le azioni correttive necessarie.

Ciò impone di stabilire, monitorare, analizzare, valutare e aggiornare le metriche per valutare le prestazioni del BCMS a intervalli regolari, oltre a mantenere un processo di *audit* interno per garantire l'allineamento con le aspettative di gestione e dell'ISO 22301. Inoltre è necessario relazionare lo Sponsor del programma e la *Leadership* organizzativa sulle prestazioni del BCMS, identificando e tracciando le azioni correttive basate sul feedback della *Leadership*, così da prepararsi a sviluppare o perfezionare azioni correttive per promuovere il miglioramento continuo.

8. Punto 10 – Miglioramento

I professionisti della *Business Continuity* facilitano le attività per identificare le opportunità di miglioramento del BCMS, implementando un processo di gestione delle azioni correttive.

Tale processo può avvalersi di un registro/file/database, in base alle esigenze dell'organizzazione, per tracciare lo stato di avanzamento e il completamento delle azioni correttive, fornendo dettagli in termini di tipologia, descrizione, data di creazione, priorità, stato, date di inizio e conclusione, persona responsabile e note. Inoltre è necessario analizzare le cause principali di non conformità, per comprendere e risolvere problemi di prestazioni, evitando che si ripetano.

È necessario, altresì, redigere report periodici per aggiornare sullo stato delle azioni correttive in corso e su eventuali deviazioni rispetto alla pianificazione.

9. Come progettare un Business Continuity Plan (BCP) – Esempio di struttura

Un formato suggerito per un BCP comprende sei sezioni (più allegati) ed è progettato per semplificare l'aggiornamento e la distribuzione del piano.

Il piano deve descrivere i processi e le procedure che garantiscono, in situazioni normali, il mantenimento e l'aggiornamento dei processi di *Business Continuity* e la funzionalità delle soluzioni previste. In situazioni di crisi, il piano deve prevedere la dichiarazione dello stato di emergenza e l'attivazione delle soluzioni di continuità per ripristinare la normale operatività.

Ogni sezione avrà un ruolo specifico nella risposta alle crisi e nel ripristino dei processi danneggiati, includendo informazioni sintetiche su ruoli e responsabilità nella gestione della crisi.

Di seguito un esempio di struttura BCP articolata in sei sezioni.

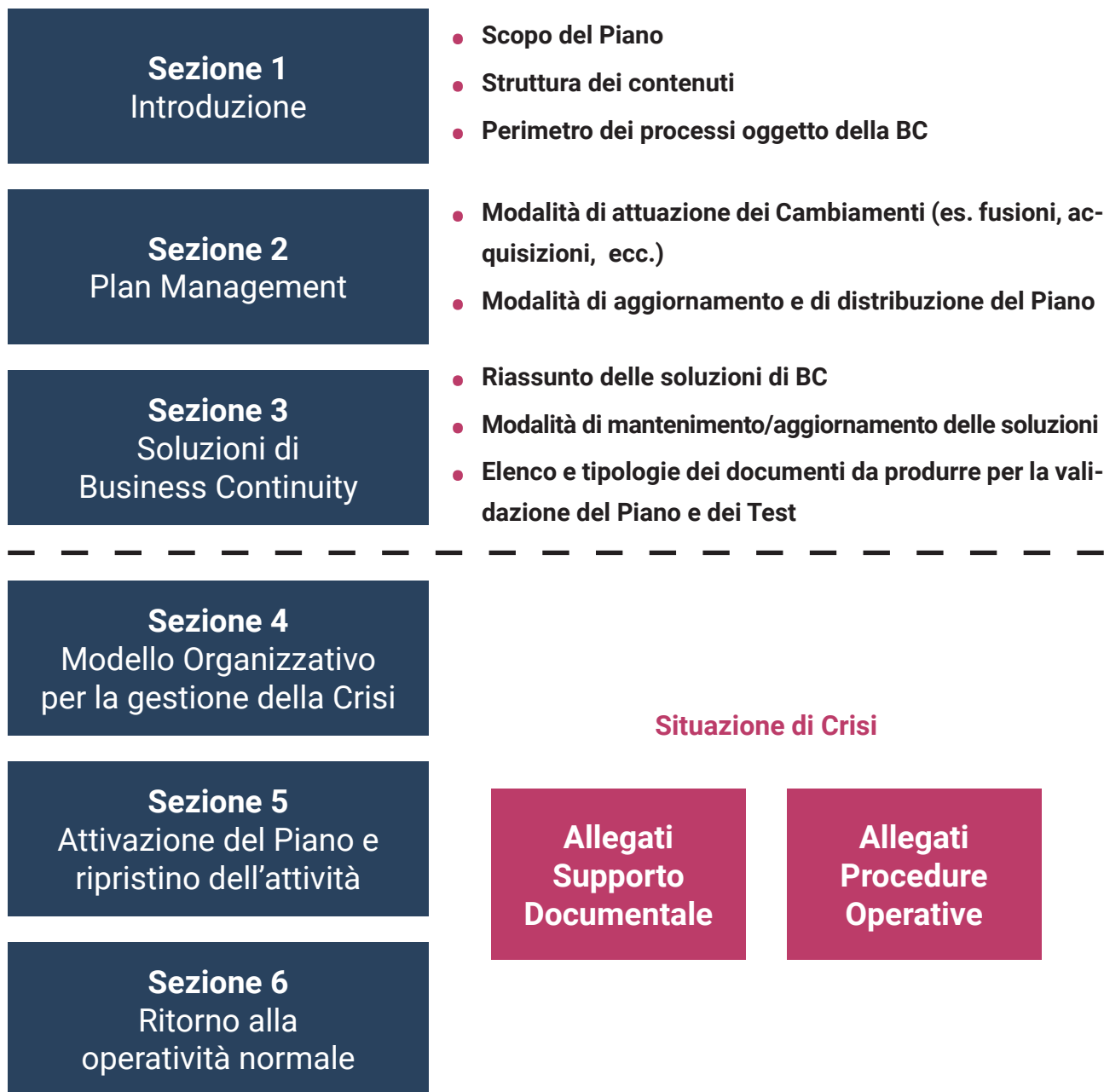


Immagine creata da Federica Maria Rita Livelli

È fondamentale che un BCP efficiente risponda a sei elementi chiave, al fine di:

1. fornire risposte chiare e complete alle domande *Chi, Cosa, Dove, Come* e *Quando*;
2. essere utile da cima a fondo;

3. specificare le azioni che devono intraprendere tutte le persone coinvolte, inclusi i responsabili dei processi critici e coloro per i quali non è stata progettata alcuna strategia;
4. essere elaborato con il coinvolgimento di tutta l'organizzazione;
5. essere scenario *independent*, ovvero indipendente da un'ipotesi specifica di scenario, poiché l'interruzione può avvenire per molteplici ragioni e il piano deve soddisfarle tutte, permettendo all'organizzazione di prendere decisioni rapide per mitigare i danni e ripartire;
6. essere sempre esercitato.

10. Disaster Recovery

Le organizzazioni che non conoscono il BCMS fanno fatica a comprendere la differenza tra BCP e *Disaster Recovery* (DR).

BCP - si riferisce al piano complessivo per garantire la continuità delle operazioni aziendali durante un evento disastroso, coinvolgendo tutti gli aspetti dell'azienda, quali: personale, sedi, comunicazioni, catena di approvvigionamento, logistica e altro ancora. Esso rappresenta la capacità, sia tattica sia strategica, delle organizzazioni e delle imprese di reagire efficacemente alle interruzioni che possono emergere nel corso delle attività aziendali.

DR - si concentra sulla tecnologia o sui sistemi informativi, comprendendo il recupero dei dati. Pertanto, la pianificazione del DR comporta la garanzia che i dati vengano archiviati e sottoposti a regolari *backup* in modo tale che i dipendenti possano accedere a piani, server, posta, file e presentazioni anche quando lavorano da posizioni esterne all'organizzazione.

Metriche del Piano di DR

Avere un piano di DR offre ai responsabili IT e ai leader aziendali la tranquillità che la loro infrastruttura sia protetta 24 ore su 24, 7 giorni su 7. Ogni piano di DR di successo implementa quattro metriche chiave, ovvero:

Failover - sposta dati, applicazioni e software su un sistema IT alternativo, solitamente in una diversa posizione, per proteggersi da eventi come incendi o inondazioni, consentendo di continuare le operazioni anche su un "sistema minimo".

Failback - riporta dati, applicazioni e software al sistema originale dopo il ripristino, assicurando che non ci siano perdite di dati e che le operazioni riprendano in modo fluido.

RTO - come già precedentemente spiegato, indica il tempo massimo che un'azienda può sostenere senza l'uso dell'IT, ovvero la durata di inattività che l'azienda può tollerare in modo pianificato.

RPO - rappresenta, come già illustrato, la perdita massima accettabile di dati; in pratica indica la frequenza con cui vengono effettuati gli aggiornamenti nella soluzione di backup (ad esempio ogni secondo, ora o giorno).

Misure di Controllo del DR

Le misure di controllo del DR sono generalmente classificate in:

- **preventive**, tese a impedire che si verifichi la minaccia;
- **investigative**, mirate a rilevare e scoprire la minaccia;
- **correttive**, che hanno come obiettivi la gestione e correzione della minaccia una volta che si sia verificata.

È doveroso ricordare che il processo di DR fa riferimento alle ISO 27001 e ISO 27031 e ha un flusso di processo standard, basato sul modello *Plan-Do-Check-Act*.

Passaggi chiave per la progettazione del DR

- Valutazioni iniziali del rischio e analisi dell'impatto aziendale per identificare i punti deboli dell'infrastruttura e le minacce potenziali.
- Impostazione di una strategia di DR e pianificazione dettagliata di come recuperare da vari livelli di interruzione.
- Formazione del personale nelle procedure di DR.
- Pianificazione di come gestire le relazioni esterne.

- Processo di manutenzione e di miglioramento continuo del piano di DR.

Di seguito è illustrato il ciclo di vita di un evento dirompente e di tutte le attività necessarie per rendere l'organizzazione resiliente.

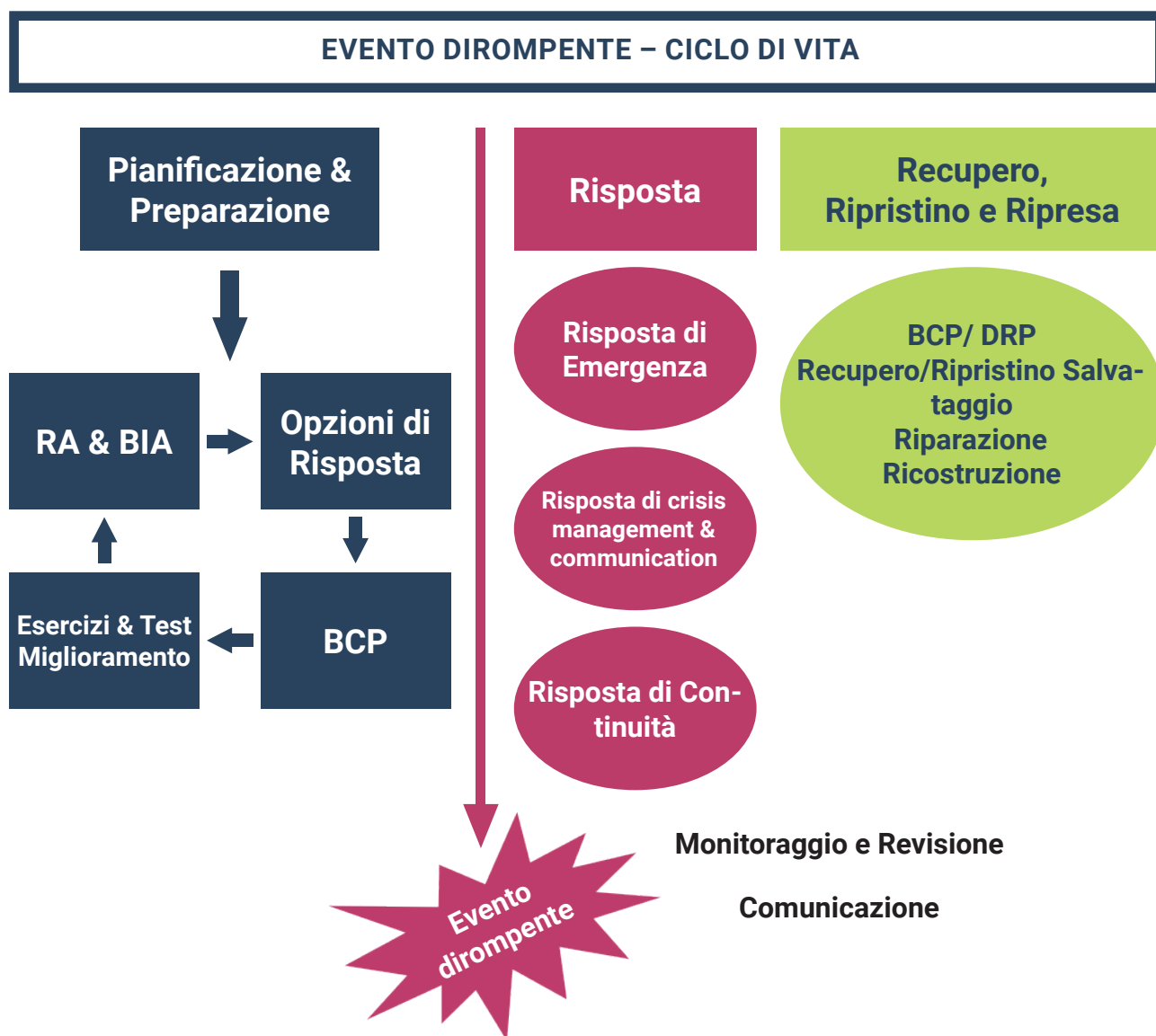


Immagine creata da Federica Maria Rita Livelli

Bibliografia

ISO 22301:2019 - Security and resilience – Business continuity management systems – Requirements

PARTE II

**GUIDA TEORICA E PRATICA DI UN
SISTEMA DI GESTIONE DI BUSINESS
CONTINUITY IN AMBITO FINANZIARIO**

A cura di:

CHIARA CAVICCHIOLI

11. Introduzione alla Parte II

Il seguente documento mira a fornire un esempio pratico di implementazione della norma ISO 22301 tramite le linee guida esaminate nella Parte I del White Paper.

L'adozione di un programma di *Business Continuity* efficace può apportare svariati benefici, non solo in caso di incidenti dagli impatti e magnitudo considerevoli ma anche da un punto di vista strategico e organizzativo, in quanto consente di avere un quadro ben definito di tutto ciò che compone e supporta l'organizzazione.

In questa seconda parte ci addenteremo dunque nelle modalità pratiche di implementazione di un programma di *Business Continuity*, tramite lo studio di un case *history* adattabile ad ogni tipo di organizzazione.

Per una maggiore comprensione del testo e della struttura della norma dal punto di vista pratico, i titoli scelti avranno come riferimento quelli della ISO 22301.

12. Contesto dell'organizzazione

Ipotizzando di voler implementare un programma di *Business Continuity* in un istituto finanziario e/o assicurativo, dovremo iniziare con un'accurata analisi del contesto organizzativo interno ed esterno.

Nell'analisi del contesto interno è indispensabile identificare il *core business* dell'entità (che potrebbe essere, ad esempio, l'erogazione di finanziamenti o l'emissione di polizze vita caso morte), cioè quel servizio / processo i cui profitti hanno un rilievo determinante nel bilancio annuale.

Tale identificazione non viene effettuata dalle singole risorse impegnate nell'implementare un programma di *Business Continuity*; bensì dal *Top Management*, supportato da altre funzioni, tra cui anche quella della BC.

Oltre all'analisi del contesto interno, è indispensabile analizzare anche il contesto esterno al

fine di comprendere la posizione dell'istituto stesso nel mercato e la posizione di eventuali *competitor*, nonché le principali ed emergenti tendenze del mercato.

Ad esempio, se emerge che la domanda dei clienti si sposta sempre più verso l'acquisto di fondi/titoli di investimento, rispetto ad altri servizi, l'istituto dovrà considerare la possibilità di adattare il proprio business sulla base di questo *trend* in crescita.

Identificare i nuovi *trend* consente di prepararsi con anticipo e in maniera strutturata, garantendo inoltre l'opportunità di identificare e gestire tempestivamente i principali rischi che possono derivarne. In ottica di contesto dell'organizzazione, è indispensabile tenere conto anche delle circostanze geopolitiche.

Gli Stati e le città in cui opera l'istituto possono essere fonti di rischi e criticità differenti. Si pensi alle prescrizioni del GDPR, a cui devono adempiere le entità operanti nel territorio europeo; o ai rischi geografici legati a un istituto finanziario operante a Venezia (per esempio) rispetto a realtà che si trovano in zone più esposte ad attacchi terroristici, come Roma.

Tutta questa serie di informazioni ci permette di avere un primo quadro generale dei rischi a cui un'entità è esposta. Tali rischi -- a differenza di quelli interni all'organizzazione -- non possono essere controllati: è soltanto possibile limitare i relativi impatti e, ove fattibile, prevenirli.

13. Leadership

Come già riportato nel presente White Paper (al paragrafo 5.2 della Parte I), il *Top Management* di un'organizzazione riveste un ruolo cruciale nella realizzazione e nell'implementazione di un programma di *Business Continuity*, in quanto è la funzione che approva il programma di BC e la sua revisione annuale, accertandosi che sia in linea con la strategia aziendale.

Si pensi ad esempio ad un fornitore a supporto di un processo critico che non fornisce garanzie di continuità operativa, non riesce a rispettare gli RTO e RPO dell'entità stessa o non ha predisposto sufficienti soluzioni di *Business Continuity* da attivare al fine di ripartire a seguito di potenziali interruzioni.

Sarà il Top Management a decidere se accollarsi il rischio e mantenere il fornitore o se sostituirlo con uno differente, in grado di fornire maggiori garanzie in termini di continuità operativa e/o *Disaster Recovery* (l'attuale normativa europea, in particolare il Regolamento DORA e la Direttiva NIS2, si focalizza proprio su tali aspetti).

Prima dell'avvio e della messa a terra del programma di *Business Continuity*, le funzioni incaricate della gestione del programma stesso, con il supporto del *Top Management*, definiscono la policy di *Business Continuity*.

Si tratta di un documento in cui sono contenute le informazioni circa l'obiettivo del programma di continuità operativa, la normativa di riferimento, le funzioni incaricate della gestione del documento, la documentazione rilevante, l'obiettivo del programma, lo scopo e le modalità delle verifiche nonché le modalità di escalation degli incidenti ad alto livello.

Un esempio di indice per una policy di *Business Continuity* può essere:

1. data di redazione e approvazione del documento;
2. introduzione e obiettivi del documento;
3. perimetro di applicazione del documento (se capogruppo e *legal entities* o solo parte di questi);
4. definizioni e normativa di riferimento;
5. documentazione interna di riferimento;
6. destinatari del documento:
 - » ruoli e responsabilità della realizzazione, gestione, divulgazione e approvazione del documento;
7. scenari compresi e coperti dalla policy e programma di continuità operativa:
 - » scenari emergenziali;
 - » scenari di crisi;
 - » scenari non coperti dal piano;

8. perimetro dei processi oggetto di analisi:
 - » modalità di conduzione delle *Business Impact Analysis*;
 - » metriche per la conduzione delle *Business Impact Analysis*;
9. ruoli e responsabilità per la gestione delle emergenze;
10. ruoli e responsabilità per la gestione delle crisi;
11. ricorso a soggetti esterni per la prestazione dei servizi ICT, fornitori, esternalizzazioni FEI e non, i.e.:
 - » modello di gestione del programma di *Business Continuity* per il rischio specifico e modelli di controllo adottati.

14. Pianificazione, Supporto e Attività Operative

14.1. Template analisi di impatto BIA

Una volta identificato il contesto organizzativo e ottenuto il supporto del *Top Management*, è possibile avviare il processo di realizzazione e implementazione di un programma di *Business Continuity*.

Il programma inizia con l'identificazione delle linee di business critiche e vitali per l'organizzazione, unitamente al *Risk Assessment* propedeutico a determinare il *Risk Appetite* e la *Risk Tolerance* dell'organizzazione.

L'identificazione delle linee di business critiche e vitali può avvenire in tre modi differenti:

1. viene comunicata dal *Top Management*;
2. viene identificata grazie alle *Business Impact Analysis*;
3. viene identificata tramite analisi di mercato e dei *competitor*.

Riprendendo l'esempio dell'istituto finanziario, il *Top Management*, dopo aver effettuato il *Risk Assessment*, fornisce il *Risk Appetite*, la *Risk Tolerance* e la *Risk Capacity*, che rispettivamente indicano:

- **Risk Appetite** - l'ammontare e tipo di rischio che un'organizzazione è disposta a perseguire o ritenere (ISO Guide 73:2009 – *Risk Management Vocabulary*);
- **Risk Tolerance** - la disponibilità dell'organizzazione o delle parti interessate a sostenere il rischio, dopo il suo trattamento, al fine di raggiungere i propri obiettivi (ISO Guide 73:2009 – *Risk Management Vocabulary*);
- **Risk Capacity** - l'ammontare di rischio massimo sopportabile per l'azienda.

È doveroso ricordare che l'attività di *Risk Assessment* è un processo volto a individuare e analizzare i rischi identificati all'interno dell'organizzazione ed è un'attività, come già riportato nella Parte I, strettamente collegata alla gestione della *Business Continuity*.

Non esistono tecniche o metodologie universali per identificare tali valori, in quanto essi variano in base alle esigenze aziendali.

Un buon punto di partenza potrebbe comunque essere il Margine di Contribuzione aziendale.¹

A titolo esemplificativo, le metriche economiche si potrebbero dunque così suddividere:

MARGINE DI CONTRIBUZIONE: € 1.000.000,00

RISK APPETITE: € 250.000,00

RISK TOLERANCE: € 500.000,00

RISK CAPACITY: € 750.000,00

¹ Intesa come la differenza tra il fatturato e i costi variabili.

La figura 1 rappresenta – a titolo esemplificativo -- come tali metriche economiche possano essere suddivise in base ai livelli di gravità (in questo caso 5), al fine di creare delle scale di impatto da utilizzare durante lo svolgimento della *Business Impact Analysis* (BIA). Tali scale possono essere variate e personalizzate anche in base al grado di precisione delle analisi che si intende perseguire.

Prendiamo ad esempio il processo bancario “Gestione Assegni Bancari”, che è stato (in questa casistica ipotetica) definito come vitale.

Al fine di analizzare tale processo, è possibile condurre l’analisi BIA in due modalità:

- svolgere un’intervista 1 a 1 con il *process owner* (alternativa sempre altamente consigliabile)
- sottoporre al *process owner* il template BIA, che dovrà compilare in autonomia e restituire al *Business Continuity Manager* (o a chi per lui).

Al fine di redigere un’analisi BIA il più corretta possibile, è necessario che il *process owner* recuperi o rediga anticipatamente un report o estratto dei movimenti e transazioni registrate, a cadenza giornaliera, almeno nell’ultimo trimestre, includendo anche particolari periodi di picco noti.

Inoltre, è sempre consigliabile (ove possibile) analizzare il processo nel modo più quantitativo possibile.

Di fatto, un’analisi troppo qualitativa potrebbe portare a un risultato finale eccessivamente basato sulla soggettività del *process owner*.

Una BIA correttamente impostata, invece, deve permettere di raccogliere almeno le seguenti informazioni:

- informazioni circa il compilatore, il ruolo e l’ufficio di appartenenza;
- il processo oggetto di analisi;
- una tabella, o elenco, in cui valorizzare i potenziali impatti economici, reputazionali e normativi (almeno) che il processo porterebbe all’organizzazione in caso di fermo (si veda figura 1);

- i razionali di impatto che hanno portato alla valorizzazione degli impatti;
- il sito (o i siti) in cui viene erogato il processo;
- il processo in input (ossia da quale processo il processo oggetto di analisi riceve informazioni);
- il processo in output (ossia il processo che riceve i dati dal processo oggetto di analisi);
- i potenziali periodi di picco del processo (ad esempio, il processo “buste paga” potrebbe avere come periodo di picco i giorni precedenti l’addebito degli stipendi) ed eventuali scadenze giornaliere;
- gli applicativi / sistemi / software utilizzati, indicandone le criticità;
- i fornitori a supporto di tale processo, indicandone la criticità;
- le attività svolte dal processo;
- le risorse ordinarie coinvolte (se il processo viene erogato per più sedi, è opportuno suddividere questo elenco per sedi);
- il numero di risorse necessarie in caso di emergenza (solitamente inferiore al numero ordinario) e dopo quanto tempo è necessaria la loro attivazione (ad esempio durante la prima ora potrebbe essere sufficiente l’operatività di una sola risorsa, dopo 2 ore tre risorse e così via);
- le risorse di backup, identificate in risorse in grado di svolgere il minimo dell’attività nel caso in cui quelle ordinarie non siano disponibili. Per tale motivo è sconsigliabile identificare risorse di backup che rientrino nello stesso Team/Ufficio delle risorse ordinarie. È possibile identificare risorse di backup primarie e secondarie per garantire una maggiore resilienza in caso di eventi avversi;
- gli apparati e strumenti utilizzati dalle risorse;

- i documenti critici (indicare se sono cartacei o digitali);
- dove sono salvati i documenti digitali (specialmente le cartelle di rete).

Al fine di agevolare il *process owner* nella corretta identificazione e classificazione degli impatti in caso di fermo del processo, alcune domande da porre potrebbero essere:

- *A quanto ammontano i mancati ricavi a seguito di fermo del processo nelle varie fasce temporali?*
- *In caso di fermo, l'istituto dovrebbe sostenere spese per far ripartire il processo, come l'ingaggio di fornitori terzi, il pagamento di straordinari dei dipendenti, etc.?*
- *Se sì, a quanto ammontano queste spese per ogni fascia temporale?*
- *Sono presenti delle scadenze ricorrenti che, se non rispettate, potrebbero comportare sanzioni normative? A quanto ammontano?*
- *Un fermo comporterebbe risonanza mediatica o impatti diretti sulla clientela, con conseguente danno reputazionale?*
- *Un fermo del presente processo porterebbe, a catena, al fermo operativo di altri processi? Se sì, con quali impatti?*

Tali analisi e la conseguente compilazione del template BIA vengono ripetute a cadenza annuale od ogni qualvolta vi siano particolari modifiche al processo, alla struttura organizzativa e/o a seguito di incidenti.

Al termine dell'analisi, si avrà dunque un quadro preciso relativo ai processi più o meno critici e da cosa sono supportati e composti.

IMPATTI	FERMO OPERATIVO IN ORE							
	0 - 4 ore	4 - 8 ore	8 - 24 ore (1 giorno)	24 - 48 ore (2 giorni)	48 - 72 ore (3 giorni)	72 ore - 1 settimana	1 - 2 settimane	2 settimane - 1 mese
Mancati ricavi								
Costi aggiuntivi								
Sanzioni normative								
Danno reputazionale								
Fermo operativo altri processi								
RTO								

BASSO	MEDIO BASSO	MEDIO	ALTO	MOLTO ALTO
Da € 100.000,00 a € 230.000,00	Da € 230.000,01 a € 360.000,00	Da € 360.000,01 a € 490.000,00	Da € 490.000,01 a € 700.000,00	Da € 700.000,01 a € 750.000,00

Figura 1. Tabella quantificazione impatti creata da Chiara Cavicchioli

14.2. Informazioni aggiuntive BIA

Se volessimo creare un'analisi di impatto ancora più dettagliata e granulare, andrebbero tenuti in considerazione i seguenti fattori.

- **Siti di Erogazione:** andrebbe assegnata una criticità che non tenga solo conto delle attività e del numero di risorse che vi lavora, ma anche della criticità del sito da un punto di vista geopolitico.
- **Applicativi:** potrebbe essere aggiunto il valore "RTO" e "RPO" del singolo applicativo, che può essere fornito dalle funzioni che gestiscono gli applicativi utilizzati dall'organizzazione. Così facendo, nella BIA si avrebbero non solo l'RTO e RPO del processo ma anche dei singoli applicativi, che potrebbero non essere identici (i *desiderata* sarebbero inferiori o uguale agli RTO e RPO del processo).

- **CIA Triad:** un ulteriore fattore di vitale importanza è analizzare il rischio di perdita di Confidenzialità, Integrità e Disponibilità del dato (nota come *CIA Triad*), le cui definizioni sono così distinte:
 - » **Confidenzialità (Confidentiality):** indica la protezione dei dati durante tutto il ciclo di vita e ha lo scopo di proteggere e preservare la riservatezza dei dati degli utenti;
 - » **Integrità (Integrity):** indica il mantenimento dell'incolumità e la salvaguardia dei dati, ossia la protezione da qualsiasi tentativo di compromissione non autorizzato;
 - » **Disponibilità (Availability):** intende garantire il diritto di accesso ai dati per gli utenti dotati dei permessi necessari.

Al fine di analizzare e quantificare tale rischio, è necessario individuare e classificare i dati ritenuti sensibili (tale attività generalmente può essere svolta prima delle analisi di impatto, creando una sorta di registro delle classificazioni con il supporto del DPO ed eventualmente delle funzioni IT).

Ai sensi della normativa GDPR, tra i dati sensibili troviamo:

- origine razziale ed etnica;
- convinzioni religiose o filosofiche;
- opinioni politiche;
- orientamento sessuale;
- situazione giudiziaria;
- informazioni relative alle comunicazioni elettroniche (indirizzo IP, social network etc);
- dati di geolocalizzazione;
- dati genetici e biometrici;

Inoltre, ulteriori tipologie di dati/asset da tenere in considerazione e da analizzare possono essere:

- proprietà intellettuali;
- software o sistemi tecnologici operativi;
- licenze;
- etc.

Durante le BIA, è importante valutare se le informazioni trattate dal processo oggetto di analisi o dal fornitore a supporto di tale processo (in quanto l'istituto continuerebbe ad essere Titolare del trattamento dei dati, mentre il fornitore risulterebbe come Responsabile) siano critiche, in quanto dati sensibili; e se, a seguito di un incidente, vi possano essere perdite di confidenzialità, integrità e disponibilità del dato.

A differenza della valutazione degli impatti suddivisa su fasce orarie, riportata alla figura 1 – che non si focalizza sullo scenario ma sul fermo del processo, indipendentemente dalla causa – durante l'analisi dei dati è opportuno considerare anche le minacce e le possibili conseguenze.

Ad esempio, un attacco *ransomware* che comprometta un processo dove le attività vengono svolte in modalità manuale e cartacea non avrà alcun impatto sulla *CIA Triad*; mentre un'alluvione che distrugga tale documentazione avrà un impatto (almeno) sull'integrità e sulla disponibilità del dato.

Inoltre, è importante considerare anche la quantità dei dati trattati.

Ipotizzando di riprendere l'analisi precedentemente effettuata per il processo "Gestione Assegni Bancari", un esempio su come svolgere la valutazione sul rischio legato ai dati può essere il seguente.

L'analisi sopra riportata (a scopo esemplificativo) può essere personalizzata sulla base delle necessità aziendali. I valori "alto-medio-basso" potrebbero, per esempio, riferirsi al numero degli utenti impattati, oppure al danno economico o reputazionale che potrebbe derivare dalla perdita di tali informazioni.

DATO	EVENTO	RISCHIO								
		Perdita di Confidenzialità			Perdita di Integrità			Perdita di Disponibilità		
		ALTO	MEDIO	BASSO	ALTO	MEDIO	BASSO	ALTO	MEDIO	BASSO
Licenza Applicativo XX	Ransomware	X			X			X		
Licenza Applicativo XX	Violazione sicurezza fisica			X			X			X
Informazioni anagrafiche emittente assegno	Ransomware	X			X			X		
Informazioni anagrafiche mittente	Phishing		X			X			X	
Informazioni anagrafiche destinatario	Ransomware	X			X			X		
Informazioni anagrafiche destinatario cartacee	Phishing			X			X			X

Figura 2. Tabella valutazione del dato creata da Chiara Cavicchioli

La valutazione e la mappatura del rischio legato ai dati può essere svolta all'interno della BIA, oppure con analisi separata, che andrà comunque a concorrere alla valutazione finale della definizione del perimetro dei processi critici.

Tale analisi potrà inoltre essere utilizzata e migliorata dalle funzioni IT, che dovranno identificare e implementare soluzioni di sicurezza atte a preservare la confidenzialità, l'integrità e la disponibilità dei dati considerati particolarmente critici.

- Risorse: sia per le risorse di emergenza che di *backup*, si possono individuare le risorse "primarie" e "secondarie" secondo il seguente criterio:

- » nel caso in cui le primarie risorse di emergenza non siano disponibili, ingaggio quelle secondarie;
- » nel caso in cui le primarie risorse di backup non siano disponibili, ingaggio quelle secondarie.

Così facendo avremo:

- risorse di emergenza primarie e secondarie;
- risorse di backup primarie e secondarie.

È utile, specialmente per i processi critici, definire quale sia il numero minimo di risorse umane necessarie per svolgere i processi in ordinario e, tra quelle attualmente presenti, quali siano quelle con il maggiore *know-how*.

In questo modo, in caso di pensionamenti e/o dimissioni, si saprà immediatamente quante risorse umane sia necessario assumere e con quale livello di *seniority*.

- **Arco temporale di svolgimento - *cut off*:** l'arco temporale di svolgimento di un processo/attività può essere più o meno critico a seconda delle tempistiche necessarie per lo svolgimento, appunto, dell'attività. Un ufficio che si occupa della gestione della compravendita di titoli avrà un arco di svolgimento quantificato in minuti e ore; mentre l'ufficio che si occupa di preparare e pubblicare l'informativa finanziaria ogni qualvolta venga rilasciato un nuovo prodotto (ipotizzando ne venga lanciato uno ogni 4 mesi) avrà un arco temporale di svolgimento di 4 mesi, quindi con una criticità bassa.

Quando si valuta questo *driver*, è importante non confondere la disorganizzazione con un'emergenza. Pertanto, ipotizzando che il lancio del prodotto avvenga il giorno 16 del mese di riferimento e che la relativa documentazione debba quindi essere pubblicata in tale giornata, un'obiezione che potrebbe essere posta in fase di analisi BIA è che un incidente che avviene il giorno 15 avrebbe un impatto alto.

Se si valutassero i processi sotto questa prospettiva, avrebbero tutti una criticità medio-alta/alta.

Inoltre, la presa in considerazione del *worst-case* scenario è utile nei casi in cui sia difficile stimare un impatto su attività/processi che sappiamo essere critici, ma non “quanto” critici, specialmente per quelli con arco temporale di svolgimento basso (ad esempio, un incidente informatico che impatti un processo alle ore 14.00, quando alle 16.00 di ogni giorno vi è una scadenza per la rendicontazione della compravendita dei titoli).

Per i processi con arco temporale di svolgimento ampio – riprendendo l’esempio della documentazione informativa – è difficile che le risorse inizino a scriverla in concomitanza della data della pubblicazione. Se l’ufficio è ben organizzato, le risorse addette avranno quindi 4 mesi per predisporre il documento ed essere pronte al lancio del prodotto; anche nel caso di incidenti che avvengano qualche giorno prima di tale data, l’azienda avrà predisposto *backup* e soluzioni di continuità propedeutiche alla ripresa dell’attività da dove è stata interrotta, senza quindi dover affrontare una perdita totale dei dati e garantendo così il rispetto della scadenza.

Nel caso in cui tali soluzioni non siano adeguate, a dover essere modificate e migliorate saranno queste ultime e non la criticità dell’arco temporale di svolgimento.

Una sintesi di tale valutazione del presente *driver* può essere riassunta dal seguente schema.

ARCO TEMPORALE DISVOLGIMENTO IN ORE	ARCO TEMPORALE DISVOLGIMENTO	CRITICITÀ ARCO TEMPORALE
1 – 8 ORE	BASSO	MOLTO ALTO
8 – 24 ORE	MEDIO - BASSO	ALTO
24 – 48 ORE	MEDIO	MEDIO - ALTO
48 – 72 ORE	MEDIO	MEDIO
72 ORE – 1 SETTIMANA	BASSO	BASSO
> 1 SETTIMANA	MOLTO BASSO	MOLTO BASSO

Figura 2. Tabella valutazione del dato creata da Chiara Cavicchioli

14.3. Calcolo RTO

A ciascun *driver* precedentemente indicato (sito di erogazione, applicativi, etc.) può essere associato un valore che concorrerà alla definizione dell’RTO.

Nella BIA in questione è stato creato un modello di calcolo che assegna un valore aggiuntivo – pari ad un 0,5% – qualora vengano selezionate le criticità “alto” e “molto alto”; questo perché, in alcuni casi, è consigliabile ragionare in ottica di *worst-case* scenario e mantenere un approccio prudentziale.

Di fronte a processi la cui criticità potrebbe oscillare tra “Medio” e “Alto / Medio Alto”, sarà dunque possibile applicare la fascia più alta, garantendo un presidio maggiormente accurato.

La scala dei valori è quindi così definita:

Basso = 1

Medio Basso = 2

Medio = 3

Alto = 4 (+ 0,5%)

Molto Alto = 5 (+ 0,5%)

La media aritmetica definisce la criticità del processo, come di seguito esemplificato.

Riprendendo le soglie di **Risk Appetite, Tolerance e Capacity** riportate al paragrafo 4.1 (rispettivamente € 250.000, € 500.000 e € 750.000), nel caso analizzato la prima fascia temporale in cui viene raggiunta la soglia *risk tolerance / risk capacity* è quella delle **24/48** ore (è possibile arrotondare per difetto e per eccesso, quindi in questo caso il 3,56 può diventare un 4²) e la media aritmetica ci suggerisce che, in caso di fermo, il processo arrecherebbe impatti economici che superano il *risk appetite* e la *risk tolerance*.

Sappiamo quindi che l’RTO oltre il quale il danno economico risulterebbe inaccettabile è di **48 ore**, in quanto si avvicina alla *risk capacity* che non deve mai essere oltrepassata.

L’organizzazione potrebbe stabilire che tutti i processi con RTO inferiore e/o uguale a 72h sono considerati critici (tale valore può ovviamente essere cambiato sulla base delle esigenze aziendali) e che quindi richiedono maggiori test annuali, soluzioni di *Business Continuity* specifiche o maggiori controlli.

2 La decisione di arrotondare per eccesso o per difetto può variare in base alla propensione al rischio dell’azienda; il presente esempio ha solo scopo illustrativo.

IMPATTI	FERMO OPERATIVO IN ORE							
	0 - 4 ore	4 - 8 ore	8 - 24 ore (1 giorno)	24 - 48 ore (2 giorni)	48 - 72 ore (3 giorni)	72 ore - 1 settimana	1 - 2 settimane	2 settimane 1 mese
Mancati ricavi	2	2	3	4	5	5	5	5
Costi aggiuntivi	1	1	1	1	2	2	2	2
Sanzioni normative	1	2	3	4	5	5	5	5
Danno reputazionale	4	4	4	4	5	5	5	5
Fermo operativo altri processi	4	4	4	4	5	5	5	5
MEDIA	2,48	2,68	3,08	3,56	4,6	4,6	4,6	4,6
RTO	48							
BASSO	1	0	230000	Valori economici fino alla risk capacity (€750.000,00 suddivisi in 5 fasce)				
MEDIO BASSO	2	230001	360000					
MEDIO	3	360001	490000					
ALTO	4	490001	700000					
MOLTO ALTO	5	700001	750000					

Figura 4. Valorizzazione tabella quantificazione impatti creato da Chiara Cavicchioli

Ogni *driver* tramite cui elaborare la BIA e calcolare l'RTO può essere variato sulla base delle esigenze aziendali.

Un ulteriore strumento di vitale importanza, che può essere utilizzato durante le analisi BIA al fine di quantificare gli impatti nella maniera più accurata possibile, è relativo agli incidenti pregressi e "*near missed*".

Le aziende dovrebbero predisporre e mantenere un elenco degli incidenti, dei relativi impatti e delle azioni implementate al fine di mitigarli. Tale elenco dovrebbe essere accessibile durante le analisi BIA, in quanto permette di quantificare un danno effettivo che la società potrebbe subire a seguito di fermo, sulla base di quanto già avvenuto in passato.

Tale strumento è utile anche perché potrebbe rivelare che, per i processi rispetto ai quali è difficile stabilire gli impatti e la relativa criticità, negli anni precedenti si sono verificati fermi operativi superiori alle 48 ore a seguito dei quali non sono stati riscontrati danni ingenti.

In questo caso sapremo quindi se, da quando è avvenuto l'incidente, non ci sono state variazioni in termini di criticità e numero delle attività svolte; e, se tale attività non è diventata parte del *core business*, tale processo non andrà ritenuto critico.

14.4. Calcolo dell'RPO

L'RPO (*Recovery Point Object*) può essere fornito dal *process owner* che sta compilando l'analisi di impatto, oppure da funzioni esterne che hanno preventivamente calcolato la criticità dei dati, stabilendo entro quanto debbano essere resi nuovamente disponibili, oltre a quantificare il margine di informazioni che è accettabile perdere (i.e. *maximum data loss*).

Solitamente – come già spiegato nella Parte I – l'RPO coincide con la periodicità del backup.

14.5. Probabilità di accadimento

Nello specifico esempio di BIA finora analizzato, si è data enfasi al potenziale impatto derivante da un fermo operativo (indipendentemente dalla sua natura), suddiviso per un determinato numero di fasce orarie. Tuttavia, alcune organizzazioni potrebbero avere necessità di considerare anche la probabilità di accadimento di un determinato evento e di analizzare gli impatti rispetto ad ogni singolo scenario.³

Tale necessità spesso deriva dal fatto che le soluzioni di mitigazione da implementare hanno sia costi iniziali, sia costi di manutenzione molto onerosi; quindi, se la probabilità di accadimento di un evento è particolarmente bassa, la soluzione più economica risulta quella di assumersi il rischio.

3 È opportuno precisare che la mappatura del rischio e delle relative probabilità di accadimento è generalmente a carico di chi si occupa di *risk management* all'interno dell'organizzazione. Dal punto di vista della continuità operativa, è consigliabile analizzare un processo sulla base del fermo operativo suddiviso in diverse fasce orarie e considerare, con il supporto della funzione rischi, anche la probabilità di accadimento durante l'analisi BIA in situazioni eccezionali in cui sia difficile quantificare gli impatti, o a fronte di spese particolarmente ingenti.

Un esempio di definizione delle percentuali da attribuire alle probabilità di accadimento di un evento, finalizzate a classificare un rischio, può essere il seguente:

- Estremamente probabile (si verifica almeno 1 volta all'anno) – 1 punto
- Probabile (si verifica almeno 1 volta ogni 2 anni) – 0,7 punti
- Probabilità media (si verifica 1 volta ogni 5/6 anni) – 0,5 punti
- Poco probabile (si verifica 1 volta ogni 10/20 anni) – 0,3 punti
- Raro (si verifica 1 volta ogni 50/70 anni) – 0,1 punti

Riprendendo l'analisi precedente, in cui abbiamo determinato che un fermo operativo di 48 ore può arrecare un danno dai € 490.000 agli € 700.000, possiamo applicare le probabilità sulla base degli scenari di rischio, come nell'esempio seguente.

- **Alluvione** – dai dati storici dell'istituto, i siti da cui viene erogato il processo non sono situati in zone soggette ad alluvioni; inoltre il rischio che tutti gli stabili da cui vengono erogati i processi siano colpiti contemporaneamente da alluvione è estremamente raro, quindi:
 - » € 595.000,00 (la metà tra € 490.000,00 e € 700.000,00) * 0,1 = € 59.500,00 (nuovo impatto economico) – rientra nel *risk appetite*.
- **Blackout** – in base ai dati storici dell'istituto e ai precedenti eventi, ogni anno a Milano e a Verona si registrano due *blackout*, quindi:
 - » € 595.000,00 * 0,5 (dividiamo a metà il punto attribuito alla classificazione "estremamente probabile" in quanto il processo viene svolto su 4 siti differenti e solo due sono coinvolti dai blackout) = € 297.000,00 – è nella soglia *risk appetite/risk tolerance*.
- **Indisponibilità applicativo** – dai dati storici dell'istituto, almeno una volta ogni 2 anni sono state riscontrate anomalie negli applicativi con una durata superiore alle 24h, quindi:
 - » € 595.000,00 * 0,7 = € 416.000,00 – è nella soglia *risk appetite/risk tolerance*.

Tali valutazioni fanno riferimento alla “*Risk Matrix*”, dove un rischio è calcolato secondo l’equazione.

RISCHIO = PROBABILITÀ X MAGNITUDO

IMPATTO	MOLTO ALTO	5	10	15	20	25
	ALTO	4	8	12	16	20
	SIGNIFICATIVO	3	6	9	12	15
	TRASCURABILE	2	4	6	8	10
	NESSUN EFFETTO	1	2	3	4	5
		IMPROBABILE	SCARSAMENTE PROBABILE	PROBABILE	FREQUENTE	MOLTO FREQUENTE
PROBABILITÀ						

Figura 5. Risk Matrix

14.6. Perimetro dei processi oggetto di analisi

Le BIA possono essere svolte secondo diverse modalità:

1. Analisi di tutti i processi;

2. Analisi dei macro-processi e dei processi sottostanti solo per i macro-processi che risultano essere critici.

L'analisi di tutti i processi è consigliabile in quanto permette di avere una fotografia e una mappatura completa di tutte le attività svolte, indipendentemente dalla criticità delle terze parti – interne ed esterne – a supporto di tali processi.

Nel caso in cui tale modalità, a causa dello scarso numero di risorse operanti in ambito *Business Continuity* o per il poco tempo a disposizione, non sia perseguibile, può essere svolta l'analisi del macro-processo utilizzando il template BIA precedentemente riportato, compilando solo la parte iniziale relativa agli impatti (con un'analisi che sarà, ovviamente, ad alto livello) e, successivamente, procedere ad analizzare i processi sottostanti, compilando anche le restanti sezioni.

Nel caso in cui l'informazione relativa ai macro-processi e alle aree di business critiche sia fornita dal *Top Management* o dalla Funzione Rischi, è a discrezione delle risorse coinvolte nella *Business Continuity* scegliere se analizzare comunque il macro-processo ad alto livello o se intraprendere direttamente le BIA per tutti i processi sottostanti.

Qualora non sia presente una mappatura dei processi, o non vi siano chiare indicazioni su dove partire con le BIA – si pensi ad un'azienda appena costituita, oppure a una società che ha la necessità di costruire e avviare un sito secondario – è consigliabile intraprendere una delle seguenti strade.

1. Identificare, con il supporto del *Top Management*, le aree lavorative che garantiscono un introito consistente e hanno rilevanza sul bilancio annuale, andando poi ad analizzare tutti i processi sottostanti; successivamente si procederà all'analisi di tutti gli altri processi.
2. Identificare i processi con output aventi impatti diretti sulla clientela (es. tutti i processi che gestiscono e sono a supporto dell'*home banking* o degli applicativi e sistemi per le operazioni di pagamento fisico o virtuale) e procedere a ritroso, analizzando successivamente i processi di supporto a questi ultimi; successivamente, si procederà all'analisi di tutti gli altri processi.

La BIA è estremamente importante, in quanto non consente solo di avere una mappa di tutti

i processi, interdipendenze e risorse dell'organizzazione, permettendo altresì, in caso di incidente, di assegnare priorità ai processi che devono ripartire prima di altri, al fine di limitare l'impatto economico, reputazionale e legale sull'organizzazione.

14.7. Soluzioni di Continuità Operativa

È doveroso evidenziare che, al termine della raccolta delle informazioni, andranno individuate delle soluzioni di *Business Continuity* da applicare ai vari processi, distinguendo tra processi critici e non.

Alcuni esempi di soluzioni a protezione dei processi critici, a seconda degli scenari, potrebbero essere i seguenti.

Indisponibilità del sistema informativo: al fine di garantire la continua disponibilità del sistema informativo, ogni suo componente viene costantemente sottoposto a "*hot backup*". Le copie dei backup sono salvate in modalità virtuale e cloud (modalità di *backup* ibrida).

Indisponibilità di dati e documenti critici: ogni documento critico viene digitalizzato e salvato in modalità ibrida su server fisici e in *cloud*. I *backup* sono automatici e le copie sono conservate tramite *storage* immutabile (ad esempio) per 5 anni.

Indisponibilità del personale critico: possono essere ingaggiate le risorse di *backup* che vengono formate ogni anno sulle principali attività che saranno chiamate a svolgere attività in caso di emergenza. Tali risorse possono essere variate durante il corso dell'anno e dovranno, in ogni caso, essere sottoposte a sessioni formative.

Indisponibilità dei siti: le risorse in possesso di accordi vigenti per il lavoro da remoto possono riprendere l'operatività da sito alternativo (es. la propria abitazione), purché vengano rispettati tutti i criteri relativi alla privacy. Qualora questa soluzione non sia percorribile, è possibile ingaggiare le risorse di *backup*.

Indisponibilità di fornitori critici: è previsto l'ingaggio di fornitori alternativi con i quali sono stati precedentemente presi accordi al fine di farli subentrare al fornitore principale e, dove possibile, rispettando gli RTO del processo. Nel caso in cui non siano presenti accordi con-

trattuali con fornitori di *backup*, è possibile valutare di re-internalizzare le attività finché non verrà identificato un nuovo fornitore.

Indisponibilità di applicativi critici: è previsto l'utilizzo di applicativi secondari per i quali sono già state predisposte funzionalità aggiuntive propedeutiche allo svolgimento di attività non ordinarie. Nel caso in cui questa soluzione non sia percorribile, è possibile valutare il ripristino delle attività per mezzo di documenti cartacei.

Indisponibilità dell'infrastruttura critica: in caso di indisponibilità delle reti di telecomunicazione ed energia elettrica, è prevista l'attivazione di reti secondarie di *backup* già contrattualizzate; nel caso non siano presenti, gli stabili sono dotati di UPS e/o gruppi elettrogeni che sono sottoposti a test e manutenzione continua e formalizzata.

Indisponibilità dei servizi ICT: laddove si verifichi un'indisponibilità di sistemi ICT a supporto dei processi critici, è prevista l'attivazione di sistemi di *backup* secondari e/o il ricorso a funzioni/fornitori terzi precedentemente testati e verificati.

Una soluzione applicabile alla maggior parte dei processi – non solo a quelli critici – potrebbe essere l'adozione del lavoro da remoto.

Tale soluzione, ovviamente, non si applica a tutte le attività che devono essere svolte *in loco*.

15. Valutazione delle prestazioni

15.1. Test

Una volta identificate le soluzioni, è indispensabile testarle al fine di verificare se, attivandole, vengano rispettati gli RTO, nonché di identificare la *Recovery Time Capability* (RTC).

La **RTC** indica la durata di tempo – effettiva, testata e comprovata – entro la quale i processi, l'infrastruttura tecnologica di supporto e i servizi aziendali critici, supportati da un fornitore, vengono ripristinati dopo un evento non pianificato. Viene misurata in avanti nel tempo, dal verificarsi iniziale di un evento non pianificato al ripristino dei servizi.

In altre parole, l'RTO identifica la soglia di tempo entro il quale i servizi erogati, la produzione, i servizi di supporto e le funzionalità operative devono essere ripristinati dopo l'incidente che ha generato la discontinuità (i desiderata oltre i quali l'impatto economico risulta insostenibile); mentre l'RTC identifica le capacità di ripristino in concreto.

Se a seguito dei test di *Business Continuity* si riscontra una discrepanza tra questi due valori, sarà necessario rivedere le soluzioni adottate. In tal caso, potrebbe quindi rendersi necessario lo stanziamento di fondi per l'implementazione di nuovi strumenti di continuità (es. l'acquisto di un generatore elettrico per i siti in cui non è presente e dove i soli UPS non riescono a garantire sufficiente energia).

Tra le varie tipologie di test di *Top Management* da utilizzare al fine di testare le soluzioni, troviamo:

- ***Table-Top Exercises***
- ***Walkthrough***
- ***Real Simulations.***

Le *Real Simulations* sono un ottimo strumento, che consente di verificare in effettivo se le soluzioni identificate garantiscano la ripartenza del processo entro l'RTO identificato.

I *Table-Top Exercises* e i *Walkthroughs* possono essere utili sia come veri e propri test, sia per preparare e formare le risorse a svolgere le *Real Simulations*.

Un esempio di test "*Real Simulations*" potrebbe essere:

- **INDISPONIBILITÀ DEL SITO**

Le risorse di emergenza operanti per il processo pagamenti alle ore 9.00 di lunedì 20/05 riscontrano che la rete elettrica non è funzionante presso lo stabile sito a Milano, via Mario Rossi 1.

Tale situazione emergenziale viene notificata al responsabile d'ufficio o al suo sostituto/*deputy*, che attiva la soluzione di *Business Continuity* del lavoro da remoto, avvisando tutte le risorse di recarsi a lavorare

presso le filiali più vicine e/o da casa.

Una volta ripristinata l'attività da remoto, l'emergenza rientra ed è possibile calcolare l'effettiva tempistica che è stata necessaria allo spostamento dei dipendenti e al ripristino del processo.

Nel caso in cui questa tempistica sfori l'RTO, si dovrà tenere in considerazione la possibilità di ingaggiare le risorse di *backup* finché le risorse ordinarie non saranno arrivate presso altra destinazione e abbiano ripreso l'operatività.

Un esempio di test "*Walkthrough*" potrebbe essere:

- **INDISPONIBILITÀ DEL FORNITORE CRITICO**

I relatori (di solito il *Business Continuity Manager* o chi per lui) preparano la trama di uno scenario in cui si ipotizza l'indisponibilità di un fornitore a supporto del processo.

Di norma, tale trama non viene condivisa con il *process owner* e le funzioni coinvolte nel processo; proprio perché, durante il test, dovranno essere loro a pensare a come gestire l'evento e a come ripartire nel rispetto degli RTO indicati.

Il *Business Continuity Manager* (o suo sostituto), una volta radunati in presenza o da remoto tutti gli utenti tester, inizierà a condividere lo scenario, eventuali aggravamenti del rischio e input, su cui i partecipanti dovranno formulare valutazioni e considerazioni per definire come gestire l'evento.

Questo scenario, per esempio, può mettere in luce eventuali lacune da parte del *process owner* (e/o chi per lui), in merito al tipo di contrattualizzazione del fornitore critico (è sempre buona norma che ne sia a conoscenza) e relative alla gestione del processo stesso.

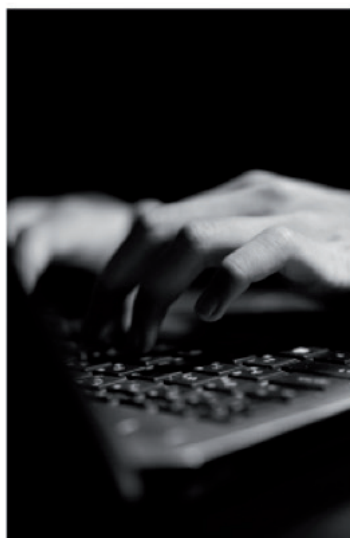
Maggiore è il coinvolgimento delle risorse nei test, maggiore sarà il livello di conoscenza della materia e consapevolezza in ambito di con-

tinuità operativa.

La cosiddetta “*awareness*”, infatti, è di sostanziale importanza per l’ottimale riuscita di un programma di *Business Continuity*: tutte le risorse, ad ogni livello, dovranno comprendere perché sia importante partecipare ai test, avere la possibilità di proporre idee e spunti di miglioramento e, quindi, essere coinvolte come parti attive. Ciò permetterà di aumentare la reattività, in termini sia di identificazione di eventuali lacune che potrebbero trasformarsi in incidenti, sia di migliore gestione di tali incidenti, a seguito delle sessioni formative e di *training*.

Il tutto, ovviamente, si traduce in minori costi e impatti, in termini economici e di tempo.

Di seguito, un esempio di come impostare una presentazione per un test in modalità “*Walkthrough*”: nell’esempio riportato è stato coinvolto un solo ufficio e si è ipotizzato che il processo riesca ad essere portato avanti tramite lavoro manuale in caso di mancanza di applicativo (è ovviamente possibile arricchire gli scenari, il numero dei partecipanti e il modo in cui sono impostate le slides).



Scenario: Indisponibilità applicativo critico

Ufficio partecipante test:

Ufficio Pagamenti

Relatori e facilitatori:

Ufficio Business Continuity & Resilience

Figura 6. Slide 1 creata da Chiara Cavicchioli



Inizio dell'evento

- ❖ Giorno: **02 maggio**
- ❖ Ore: **10:05 a.m.**

Durante lo svolgimento delle quotidiane attività, Rossi Diego riscontra una problematica in fase di accesso applicativo «TuoAssegno».

Diego si confronta con i colleghi, i quali confermano di aver riscontrato la stessa problematica.

Cosa devono fare le risorse operanti tramite applicativo «TuoAssegno»?

Chi devono contattare?

Per quanto tempo possono rimanere senza applicativo?

Figura 7. Slide 2 creata da Chiara Cavicchioli



Inizio dell'evento

- ❖ Giorno: **02 maggio**
- ❖ Ore: **10:20 a.m.**

Il responsabile dell'Ufficio Pagamenti contatta l'Ufficio Applications per chiedere informazioni relativamente al fermo operativo dell'applicativo «TuoAssegno».

La risorsa di riferimento, Marco, riferisce che il blocco applicativo non è legato a problematiche sui sistemi interni, ma del fornitore.

Come dovrebbero comportarsi le risorse operanti per mezzo dell'applicativo «TuoAssegno»?

Vi è modo di riprendere l'operatività senza tale applicativo?

Figura 8. Slide 3 creata da Chiara Cavicchioli

Tutte le risultanze, la tipologia di test, gli attori coinvolti e gli spunti di miglioramento emersi devono essere formalizzati in appositi documenti/registri che possono essere messi a disposizione delle funzioni di *Audit*.

Ogni anno, specialmente all'inizio della campagna di rinnovo del programma di *Business Continuity*, dovranno essere formalizzati il numero e la tipologia di test che l'entità intende svolgere durante l'anno.

Tale elenco dovrà essere sottoposto e approvato dal *Top Management*, che sarà incaricato – se necessario – di stanziare fondi aggiuntivi allo svolgimento dei test e potrà chiedere una revisione della tipologia di processi e di test oggetto delle sessioni di *training*.

Si consiglia di testare su base annuale almeno i processi più critici, considerando ogni volta scenari differenti.

15.2. Fornitori e interdipendenze

In concomitanza con lo svolgimento dei test, è fondamentale mappare i fornitori identificati come critici o a supporto di processi critici, nonché quelli che forniscono un applicativo ritenuto critico. È opportuno richiedere a tali fornitori di consegnare i loro piani di *Business Continuity* e/o *Disaster Recovery*, i verbali di conduzione dei loro test di BC e, in aggiunta, una copia delle eventuali certificazioni in vigore in tali ambiti.

Inoltre – quando possibile – è consigliabile che l’invio di tali documenti avvenga prima della stipula del contratto, poiché, se ciò avvenisse in un secondo momento e i Piani del fornitore non fossero idonei, l’organizzazione correrebbe il rischio di non poter svolgere i processi supportati da tale fornitore in caso di evento avverso.

La consegna della sola certificazione o di piani di *Business Continuity* e/o *Disaster Recovery* poco esaustivi, o con sezioni addirittura nascoste, non dovrebbe essere ritenuta valida.

La sola certificazione, infatti, non è una prova sufficiente che l’organizzazione sia in grado di ripartire nel minor tempo possibile a seguito di eventi avversi. Inoltre, rendere inaccessibile la totalità del documento potrebbe portare a non avere visione di informazioni importanti.

In questi casi, o nel caso in cui i documenti non siano ritenuti idonei, l’organizzazione stessa potrebbe valutare di dare supporto al fornitore nella stesura di un piano di BC “condivisibile”, in cui siano riportate e lasciate in chiaro le informazioni di maggiore interesse.

È inoltre consigliabile, con il supporto delle funzioni che si occupano di gestire la parte di *supply chain*, definire le clausole contrattuali da sottoporre al fornitore in termini di *Business*

Continuity, gli RTO e RPO che sarà chiamato a rispettare ed eventuali SLA da attivare in caso di mancata osservanza di questi ultimi.

Oltre agli RTO e agli RPO, è consigliabile inserire clausole circa la documentazione e le attività che l'istituto si aspetta di ricevere dal fornitore, quali ad esempio la consegna annuale del piano di BC rinnovato, la consegna delle certificazioni, la possibilità di far partecipare il fornitore ai test svolti dall'organizzazione, il numero e tipologia dei test che si desidera il fornitore svolga e la ricezione dei relativi verbali.

Laddove possibile, è consigliabile prendere parte ai loro test come ospiti, al fine di constatare concretamente il grado di maturità dell'azienda in relazione a queste tematiche. Inoltre, sulla base del livello di preparazione dell'entità finanziaria stessa e del fornitore, è possibile svolgere test congiunti con uno o più fornitori: ciò permetterà di avere dettagli sulle effettive soluzioni da attivare in caso di indisponibilità di alcuni di essi, comprendere come possano garantire supporto all'istituto finanziario e conoscere le azioni da mettere in campo in modo congiunto al fine di ripartire.

Inoltre è sempre opportuno, ove possibile, prevedere nei contratti delle clausole relative alla strategia d'uscita, che facilitino il recesso dal contratto da ambo le parti nel caso vengano a mancare le garanzie in termini di sicurezza di erogazione dei servizi forniti, unitamente alle clausole che garantiscano all'organizzazione il pieno supporto da parte del fornitore, nel caso in cui quest'ultimo eroghi lo stesso servizio a più organizzazioni colpite da un medesimo evento e nello stesso frangente temporale.

Nel caso in cui un fornitore già contrattualizzato non rispetti i requisiti richiesti nel contratto (ad esempio non consegna i verbali dei test svolti durante l'anno, non conceda la partecipazione ai test quando è invece stata contrattualizzata, non fornisca più sufficienti garanzie di *Business Continuity* o non rispetti gli RTO e gli RPO dichiarati in caso di incidente), ciò verrà portato all'attenzione del Top Management, che valuterà se accettare il rischio di continuare a mantenere rapporti con tale fornitore o se sostituirlo con altri.

Per ogni fornitore – e specialmente per le grosse aziende – è consigliabile identificare un referente del fornitore, che si occuperà di tenere i contatti e fungere da “collante” tra l'ufficio che si occupa di gestire il programma di *Business Continuity*, l'ufficio acquisti e il fornitore stesso.

Per le aziende più strutturate, è addirittura possibile implementare una funzione che si occupi in prima persona della gestione delle terze parti dal punto di vista della *Business Continuity* e che tenga quindi i rapporti diretti con ogni fornitore.

Inoltre, al fine ultimo di avere un quadro sempre aggiornato e chiaro rispetto alla documentazione prodotta e consegnata dal fornitore, è possibile creare una mappa con dei *rating* per ognuno, da aggiornare con una cadenza almeno annuale.

I punteggi potranno essere personalizzati e variati in base a diversi driver, tra cui, per esempio:

- **Consegna del piano di business continuity (+ 1 punto)**
 - » Consegna di un piano aggiornato (+1 punto)
 - » Se consegna di un piano non aggiornato all'anno in corso (- 0,5 punto)
 - » Piano di continuità esaustivo che contenga almeno: ruoli e responsabilità, scenari coperti dal piano, soluzioni di continuità operativa, driver di analisi dei processi esaustivi, numero dei processi critici, siti dove vengono erogati i processi, numero e tipologia dei test svolti durante l'anno (+1 punto)
 - » Se piano di Business Continuity non esaustivo o con parti nascoste (- 1 punto)
- **Consegna elenco verbali dei test svolti (+1 punto) (qui andrebbe definito dall'organizzazione il numero minimo dei test che ci si aspetta che i fornitori svolgano annualmente)**
 - » Esito positivo almeno di tutti i test richiesti (+1 punto)
 - » Esito test positivo ma numero test insufficiente (- 0,5 punto)
 - » Esito test negativo ma successivamente ripetuti con esito positivo e documentazione riportante le azioni mitigative implementate per far fronte alla problematica che ha portato all'esito negativo; numero di test effettuati sufficiente (+1 punto)

» Esito test negativo ma successivamente ripetuti con esito positivo/negativo e documentazione riportante le azioni mitigative implementate per far fronte alla problematica che ha portato all'esito negativo; numero di test effettuati insufficiente (- 1 punto)

- Possibilità di partecipazione ai test di Business Continuity (+1 punto)
- Possibilità di coinvolgere il fornitore ai test interni (+1 punto)
- Consegna delle certificazioni (+ 1 punto)

FORNITORE	RATING FORNITORE												RATING FINALE
	Consegna del piano di continuità operativa	Consegna di un piano non aggiornato all'anno in corso	Piano di continuità esaustivo	Piano di continuità operativa non esaustivo o con parti nascoste	Consegna elenco verbali dei test svolti	Esito test positivo di almeno tutti i test richiesti	Esito test positivo ma numero test insufficiente	Esito test negativo ma successivamente ripetuti con esito positivo e documentazione riportante le azioni mitigative implementate per far fronte alla problematica che ha portato all'esito negativo e numero di test effettuati sufficiente	Esito test negativo ma successivamente ripetuti con esito positivo e documentazione riportante le azioni mitigative implementate per far fronte alla problematica che ha portato all'esito negativo e numero di test effettuati insufficiente	Possibilità di partecipazione ai test di continuità operativa	Possibilità di coinvolgere il fornitore ai test interni	Consegna delle certificazioni	
Your Solution	1	0	1	0	1	1	0	1	0	1	1	1	8
Your Supplier	1	0	0	-0,5	1	1	0	0	0	1	0	1	4,5
Your Solution	1	0	0	0	1	0	0,5	0	0	0	0	1	2,5

Figura 9. Tabella esemplificativa per rating fornitore creata da Chiara Cavicchioli

Nel caso specifico, è assegnata una penalizzazione di 0,5 punti se:

- viene consegnato un piano non aggiornato all'anno in corso;
- l'esito dei test svolti è positivo ma il numero test insufficiente;

in quanto il fornitore non è stato in grado di fornire la documentazione più aggiornata ed esaustiva possibile ma dimostra, comunque, di avere un programma di *Business Continuity* e di svolgere dei test durante l'anno.

È stata invece assegnata una penalizzazione maggiore (pari ad 1 punto) se, a seguito di

esito test negativo, i test vengono successivamente ripetuti con esito positivo/negativo e la successiva documentazione prodotta riporta le azioni mitigative implementate per far fronte alla problematica che ha portato all'esito negativo ma i test effettuati risultano insufficienti o inesistenti; dato che, in una casistica simile, il fornitore dimostrerebbe di non essere in grado di ripartire nella maniera più adeguata e veloce possibile e di non riuscire a implementare e documentare le azioni mitigative.

Una tabella analoga (può essere arricchita a piacere) potrebbe essere implementata e mantenuta anche in relazione agli incidenti.

Ad esempio:

- Comunicazione tempestiva dell'incidente (+1 punto)
- Comunicazione non tempestiva dell'incidente (- 0,5 punti)
- Comunicazione continua circa lo stato dell'incidente (+ 1 punto)
- Comunicazione non continua circa lo stato dell'incidente e spesso sollecitata (- 0,5 punti)
- Rispetto dell'RTO e RPO (+ 1 punto)
- Mancato rispetto dell'RTO e RPO (-1 punto)
- Ricadute sull'istituto a seguito di incidente (- 1 punto)
- Impatto mediatico con possibili ricadute sull'istituto (- 1 punto)
- Mancato rispetti degli SLA contrattuali (+ 1 punto)
- Rispetto degli SLA contrattuali (+ 1 punto)
- Implementazione e test delle soluzioni di mitigazione post evento (+1 punto).

In aggiunta ai fornitori, è indispensabile mappare e analizzare con maggiore dettaglio gli applicativi, i sistemi e la documentazione ritenuta critica ai fini della BIA.

È infatti importante effettuare una mappatura che consideri l'applicativo critico, il fornitore

che fornisce tale applicativo, dove sia conservata la documentazione ritenuta critica e cosa supporti.

In relazione ad applicativi e sistemi, è opportuno mapparne e verificarne le interconnessioni con il supporto delle funzioni interne che si occupano di gestire e mantenere i software, i sistemi e gli applicativi, al fine di individuare se, in caso di interruzione di un sistema e/o applicativo, vi sia un effetto a catena tale da poter causare l'indisponibilità di terzi applicativi e dei processi da essi supportati.

Un esempio potrebbe essere:

- Sistema "Pagoyou", i.e. la piattaforma di vendita digitale *home banking*. Tale sistema è connesso e quindi può compromettere la funzionalità dei seguenti applicativi:
 - » "TuoConto", applicativo per la gestione e visualizzazione del portafoglio cliente;
 - » "TuoNuovoProdotto", applicativo per la vendita di nuovi prodotti bancari;
 - » "TuoAssegno", applicativo per la gestione degli assegni bancari per destinatari residenti in Italia.

Maggiori sono la granularità e profondità con cui si analizza tutta l'infrastruttura a supporto di un processo e maggiori sono le probabilità che, in caso di evento, questo potrà essere gestito in modo ottimale e tempestivo.

Un'analisi approfondita consente, inoltre, di individuare in anticipo possibili lacune da colmare.

Nel caso in cui gli applicativi "TuoConto", "TuoNuovoProdotto" e "TuoAssegno" siano stati ritenuti critici all'interno di una BIA relativa a un processo critico, sarà necessario identificare soluzioni di *Business Continuity* che garantiscano la loro operatività anche in caso di indisponibilità di "Pagoyou".

Tale mappatura consente di anticipare potenziali effetti "a catena" in caso di incidenti o malfunzionamenti riguardanti un applicativo, sistema e/o fornitore.

16. Piano di continuità operativa (BCP – Business Continuity Plan)

Al termine delle BIA e dei test, nonché della mappatura dei fornitori, degli applicativi, dei sistemi e della documentazione critica, è possibile iniziare la stesura del BCP.

- Un BCP ben strutturato deve contenere almeno i seguenti elementi:
- Data della stesura e/o revisione e nominativi/ruoli degli approvatori
- Normativa di riferimento (nel caso non sia già stata esplicitata nella policy di continuità operativa)
- Finalità del piano e programma di continuità operativa
- Ruoli e responsabilità suddivisi per *legal entities* (quando presenti)
- Scenari coperti dal BCP che, nel caso specifico, sono:
 - » indisponibilità dei siti;
 - » indisponibilità dei sistemi informativi critici;
 - » indisponibilità dei fornitori;
 - » indisponibilità degli applicativi, dati e documentazione critica;
 - » indisponibilità dell'infrastruttura critica,
 - » indisponibilità delle risorse;
 - » calamità naturali;

non è quindi compreso lo scenario di un attacco informatico. Nel caso in cui si voglia far rientrare anche tale scenario tra quelli coperti dal piano, sarà necessario predisporre e testare soluzioni di BC ad *hoc*, oltre a impostare le BIA al fine di quantificare anche tale rischio.

- Criteri di esecuzione delle BIA. Nel nostro caso specifico le BIA si basano sui seguenti *driver*:

- » mancati ricavi;
- » costi aggiuntivi;
- » sanzioni normative;
- » danno reputazionale;
- » fermo operativo di altri processi.
- Andranno inoltre considerati ulteriori aspetti, quali:
 - » razionali di impatto;
 - » siti di erogazione;
 - » processi in Input;
 - » descrizione Input;
 - » processi in Output;
 - » descrizione Output;
 - » periodi di lavoro di picco;
 - » scadenze giornaliere (*cut-off*);
 - » eventuali *Legal Entities* servite;

che, nel nostro caso specifico, non concorrono alla definizione dell'RTO.

Nel caso in cui vogliano essere integrate, sarà sufficiente attribuire un algoritmo alla tabella in modo che nel calcolo finale anche a queste voci venga attribuito un peso (che va definito con la Funzione Rischi).

L'elenco delle soluzioni di *Business Continuity* identificate, che potrebbe configurarsi come allegato del Piano in cui vengono riportate le soluzioni identificate per ogni processo considerato critico.

Criteri in base ai quali il piano deve essere attivato, ad esempio:

IMPATTO	CONSEGUENZE	AZIONI
LIVELLO 1 - BASSO	Compromissione di alcune funzionalità di un numero limitato e circoscritto di processi critici e/o non critici.	La situazione di emergenza viene presidiata e gestita in modo ordinario, senza necessità di attivazione delle soluzioni di continuità operativa
LIVELLO 2 - MEDIO	Compromissione e indisponibilità di un numero significativo di processi critici e/o seri danni al personale, alle infrastrutture tecnologiche, fornitori critici e applicativi.	La situazione di emergenza viene presidiata e gestita per mezzo dell'attivazione del piano e delle soluzioni di continuità operativa.
LIVELLO 3 - ALTO	Compromissione e indisponibilità totale di un numero significativo di processi critici, del sistema informativo, di fornitori critici e applicativi.	La situazione di emergenza richiede l'adozione di misure di contenimento straordinarie. Può essere attivato il comitato di crisi e dichiarato lo stato di crisi.

Figura 10. Criteri di attivazione del piano di continuità operativa creati da Chiara Cavicchioli

- Gli strumenti a supporto del piano (ad esempio, il Piano delle Emergenze realizzato dalle funzioni incaricate della gestione della sicurezza, il piano di *Disaster Recovery* etc.)
- Le tempistiche di ripristino e gli obiettivi dei punti di ripristino dei processi critici (è possibile creare un elenco che andrà a far parte degli allegati del piano, contenente i processi critici e non critici con i relativi RTO, RTC e RPO)
- Le procedure di escalation da eventi classificati come “Livello 1 - Basso” al livello “Livello 2 - Medio” e/o al “Livello 3 - ALTO” e i ruoli coinvolti
- La procedura di comunicazione interna ed esterna durante l'emergenza (quali sono gli utenti interessati e chi si occupa di darne comunicazione e con quali modalità)

- I relativi allegati, che comprenderanno:
 - » **Catena di comando e di controllo:** contiene i nominativi delle funzioni incaricate della gestione del programma di continuità operativa, le funzioni di emergenza e *backup* relative alla continuità operativa, le modalità di ingaggio ed *escalation* di una situazione emergenziale che può diventare una crisi, dove sono situate le *war room* (o sale di crisi, cioè gli ambienti fisici o virtuali in cui si ritrovano le funzioni e ruoli incaricati di gestire un evento) e un elenco di altre funzioni che potrebbero essere coinvolte a gestire un evento con i rispettivi recapiti (es. il CISO della capogruppo, il responsabile della funzione immobili, il responsabile della Sicurezza, il responsabile della funzione degli incidenti di sicurezza fisica e/o virtuale, il responsabile dell'ufficio *procurement* che gestirà i fornitori, il responsabile del personale, etc.)
 - » **Allegato - Elenco dei siti:** indica tutti i siti in cui vengono erogati i processi e la loro criticità. Tale informazione può essere fornita dall'ufficio che si occupa della quantificazione e gestione dei rischi.
 - » **Allegato - Elenco dei processi:** riporta tutti i processi che sono stati oggetto di analisi BIA durante l'anno, il relativo ufficio di riferimento e responsabile, il sito dal quale vengono erogati, l'ufficio sotto il quale sono collocati, gli applicativi e i fornitori a supporto.
 - » **Allegato - Elenco degli applicativi:** riporta gli applicativi mappati durante le analisi BIA (specialmente per quelli con criticità alta) e i relativi processi di riferimento. È inoltre consigliabile inserire le varie interconnessioni con altri applicativi/sistemi.
 - » **Allegato - Elenco dei fornitori:** riporta i fornitori a supporto dei processi oggetto di analisi BIA, suddividendoli (quando necessario e se presenti) tra fornitori normali, esternalizzazioni ed esternalizzazioni FEI (Funzioni Essenziali e Importanti). Per ognuna di queste voci è necessario riportare la criticità dei fornitori e dei

processi da essi supportati, oltre al nominativo di un referente interno che si occupa di tenere i rapporti con tale fornitore. È consigliabile indicare anche numero del contratto e tipologia del servizio erogato, al fine di facilitarne l'individuazione in caso di emergenza.

- » **Allegato - Elenco delle risorse umane coinvolte:** riporta tutte le risorse identificate come di emergenza e di *backup* ai fini delle analisi BIA, i relativi recapiti e l'ufficio di appartenenza, oltre al sito nel quale lavorano (riprendendo l'esempio della tabella BIA, Rossi Diego – matricola 0001 è una risorsa di emergenza per l'ufficio sito a Milano, ma può essere risorsa di *backup* per il sito di Verona) e i loro recapiti.
- » **Allegato - Elenco dei test svolti:** riporta i test svolti durante l'anno e i relativi esiti. Tale elenco dovrebbe contenere un numero di test almeno pari a quello redatto ad inizio anno e approvato dal *Top Management*, includendo anche l'elenco dei test svolti dai fornitori.
- » **Allegato - Elenco dei rischi residui:** riporta tutti i rischi residui identificati durante tutta la gestione del programma di *Business Continuity*, quali ad esempio i processi per i quali le soluzioni di BC identificate non sono sufficienti a garantire l'RTO desiderato, i fornitori che non hanno rispettato i requisiti richiesti, eventuali processi per i quali non siano presenti siti e/o risorse di *backup* e tutti gli ulteriori "colli di bottiglia" (ossia i rischi per i quali non ci siano soluzioni secondarie attivabili) identificati e che devono essere portati all'attenzione del *Top Management*.

Tale piano – contenente almeno tutte le informazioni precedentemente elencate – dovrà essere redatto per tutte le società del gruppo; oppure, nel caso si decida di mantenere la gestione del programma accentrata presso la capogruppo, le informazioni e gli allegati dovranno fare riferimento anche alle *legal entities*.

17. Miglioramento continuo

Le *Business Impact Analysis*, i test e le mappature devono essere nuovamente svolte e/o aggiornate – assegnando un numero progressivo alla relativa documentazione – con cadenza annuale, o altresì a fronte di cambiamenti significativi all'interno dell'organizzazione.

Nell'anno successivo e all'avvio del nuovo programma, dovranno essere indicati e recepiti tutti gli spunti di miglioramento emersi l'anno precedente: ciò al fine di promuovere un'ottica di miglioramento continuo del BCP e, ove possibile, colmare i *gap* di eventuali rischi residui emersi.

Forum ICT Security

23^a Edizione

Auditorium della Tecnica, Roma

Novembre

19 e 20 NOVEMBRE 2025

**08 am -
04 pm**

Iscriviti sul sito web:

ictsecuritymagazine.com



WHITE PAPER LUGLIO 2025

ICT SECURITY MAGAZINE

With more than 20 years of experience, the magazine tackles the latest news in the sector with targeted in-depth analysis and provides the reader with new ideas and guidelines to improve and expand their knowledge keeping pace with continuous innovation.

WWW.ICTSECURITYMAGAZINE.COM